



PGP • TREINAMENTO



EDIÇÃO DE 13 DE JUNHO DE 2026

Cartilha *do PGP*

*Guia de Implementação da LGPD
em Instituições Públicas*

Programa de Governança em Privacidade — método em sequência:
Preliminar + 7 fases, modelos institucionais e capítulos de consulta.

8

Etapas do PGP
(Preliminar + 1-7)

5

Modelos integrados

10

Capítulos de consulta

Sumário

19 capítulos organizados em 3 grandes blocos.



1 CAPÍTULO

Introdução

- 01  Apresentação · Como ler esta Cartilha



8 CAPÍTULOS

Etapas do PGP

- 02  Fase Preliminar — Sensibilização e Engajamento · Fase Preliminar
- 03  Fase 1 — Formação das equipes de trabalho · Fase 1
- 04  Fase 2 — Diagnóstico Inicial · Fase 2
- 05  Fase 3 — Mapeamento e Análise de Riscos · Fase 3
- 06  Fase 4 — GAP Analysis · Fase 4
- 07  Fase 5 — Plano de Ação e Adequação · Fase 5
- 08  Fase 6 — Execução · Fase 6
- 09  Fase 7 — Monitoramento Contínuo e Melhoria · Fase 7



10 CAPÍTULOS

Capítulos de consulta

- 10  Glossário LGPD essencial · Glossário
- 11  Base legal — guia decisivo para o Setor Público · Base legal
- 12  Armadilhas comuns no setor público · Armadilhas
- 13  Adaptação por porte do órgão · Adaptação
- 14  Calendário recomendado de revisões · Calendário

- 15  Checklist final do PGP · Checklist
- 16  Perguntas frequentes (FAQ) · FAQ
- 17  Referências externas curadas · Referências
- 18  Roteiros de implementação por prazo · Roteiros
- 19  Encerramento · Encerramento



INTRODUÇÃO • COMO LER ESTA CARTILHA

Apresentação

Esta Cartilha consolida, em formato pragmático e auto-suficiente, o caminho de implementação da Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais (LGPD) — em Instituições Públicas brasileiras. É material institucional pra uso INDEPENDENTE: não exige treinamento prévio, não depende de aplicativo, não requer conhecimento técnico avançado. O Encarregado e o Comitê de Privacidade do órgão podem usá-la como base de partida pra estruturar o Programa de Governança em Privacidade (PGP) da Instituição.



O que esta Cartilha NÃO é

- ▶ NÃO é parecer jurídico institucional — orienta, não vincula a Instituição perante a ANPD.
- ▶ NÃO substitui consulta a especialistas em casos de dúvida significativa.
- ▶ NÃO é exaustiva — a LGPD tem 65 artigos + dezenas de Resoluções; aqui condensamos o essencial pra o setor público.
- ▶ NÃO é receita única — Instituições diferem em porte, contexto e cultura; adaptar é parte do trabalho.



Como usar

Leitura em sequência — pra quem está começando do zero. Cada fase do PGP (Preliminar + 7 fases) está organizada em sequência. Lendo do início ao fim, fica claro o método completo.

Consulta pontual — pra dúvidas específicas. Use o sumário pra ir direto ao instrumento que está estruturando: Inventário • Riscos • GAP • Plano • RIPD • Aviso • DSR • Operadores • Incidentes • PRI.

Apoio à capacitação — pra capacitar a equipe. Os capítulos FAQ (perguntas frequentes), Glossário, Base Legal e Armadilhas Comuns servem de material

didático em treinamentos internos.



Estrutura

- ▶ 8 etapas do PGP (Preliminar + Fases 1-7) com conteúdo institucional e modelos — a jornada completa, em sequência
- ▶ Modelos de documentos: Política do PGP · Comunicação ANPD · Cláusulas LGPD · Retenção · Consentimento
- ▶ Capítulos de consulta (no final): Glossário LGPD essencial (30 termos) · Base Legal — guia decisivo (Art. 7º + Art. 11)
- ▶ Armadilhas comuns no setor público (10 situações reais)
- ▶ Adaptação por porte (pequeno · médio · grande)
- ▶ Calendário de revisões recomendado
- ▶ Checklist final do PGP (25 perguntas)
- ▶ FAQ — perguntas frequentes (15+ respostas detalhadas)
- ▶ Referências externas curadas
- ▶ Roteiros de implementação por prazo (30 dias · 90 dias · 12 meses)



Fase Preliminar — Sensibilização e Engajamento



Conteúdo institucional

A Fase Preliminar é o degrau zero do Programa de Governança em Privacidade. Antes de mapear processos, antes de designar Encarregado, antes de qualquer instrumento técnico, o órgão precisa ter a Alta Gestão CONVENCIDA de que LGPD é prioridade institucional — não tarefa de TI nem capricho do Jurídico.

Sem esse patrocínio explícito do dirigente máximo, qualquer esforço posterior fica órfão: a Comissão não se reúne, o orçamento não sai, as áreas técnicas não cooperam, e o DPO vira figura decorativa. Por isso o curso começa AQUI, antes mesmo da nomeação formal do Encarregado.

• Como proceder

- ▶ Aplicar o Termômetro: auto-diagnóstico individual em 2 blocos — quanto cada pessoa conhece a LGPD (3 perguntas) e em que etapa da jornada a Instituição está (7 perguntas, uma por etapa do PGP). Identifica de onde se está partindo.
- ▶ Escrever a Carta para a Alta Gestão: documento institucional curto com destinatário, justificativa legal, riscos de não-cumprimento, pedido de apoio concreto e assinatura do Encarregado (ou da liderança que conduzirá o trabalho).
- ▶ Apresentar um Roadmap inicial de 90 dias com marcos verificáveis — mostrar que existe um plano concreto, não promessas genéricas.
- ▶ Obter comprometimento formal: idealmente um Ato/Despacho do dirigente máximo aprovando o início do PGP e prevendo recursos.

O que essa fase ENTREGA

Não é documento técnico — é decisão institucional. Sai da Fase Preliminar com (a) consciência da equipe sobre o ponto de partida, (b) apoio formal da Alta Gestão por escrito, e (c) cronograma inicial acordado. Sem isso, as Fases 1-7 viram exercício formal sem tração real.



Modelos de referência

- **Termômetro — ferramenta de auto-diagnóstico (você + sua Instituição)**

Ferramenta de auto-diagnóstico em 2 blocos com scores separados: o primeiro mede o conhecimento de CADA PESSOA sobre a LGPD (3 perguntas); o segundo mede em que etapa da jornada de adequação a INSTITUIÇÃO está (7 perguntas — uma por etapa do PGP). Aplicar no início do trabalho (linha de base) e repetir periodicamente (semestral / anual) pra evidenciar a evolução. Cada pergunta tem 4 alternativas em escala crescente.

Parte 1 — Sobre você (conhecimento pessoal):

 Qual o seu contato com a LGPD até hoje?

 No seu trabalho, você saberia dizer o que pode e o que não pode fazer com dados de pessoas?

 Se acontecer um problema com dados pessoais (vazamento, reclamação de cidadão), você sabe o que fazer?

Parte 2 — Sobre a sua Instituição (uma pergunta por etapa do PGP):

 Os chefes (prefeito/presidente, secretários, diretores) compram a ideia de proteger dados?

Etapa correspondente: Fase Preliminar — engajar quem decide.

 Tem alguém responsável por proteção de dados no órgão?

Etapa correspondente: Fase 1 — Encarregado e equipes de trabalho.

 Vocês sabem quais dados de pessoas o órgão usa e onde ficam guardados?

Etapa correspondente: Fase 2 — Diagnóstico inicial (Inventário de Dados).

 Vocês avaliam os riscos antes de usar dados delicados (saúde, crianças, etc.)?

Etapa correspondente: Fase 3 — Mapeamento e Análise de Riscos.

 Vocês já compararam o que fazem hoje com o que a Lei exige, pra achar o que falta?

Etapa correspondente: Fase 4 — GAP Analysis (o que falta pra cumprir).

 Existe um plano com prazos pra resolver o que falta — e ele sai do papel?

Etapa correspondente: Fases 5 e 6 — Plano de Ação e Execução.

 Depois de ajustar, vocês acompanham e revisam de tempos em tempos?

Etapa correspondente: Fase 7 — Monitoramento Contínuo e Melhoria.

O formulário completo (com as 4 alternativas de cada pergunta, a pontuação e as faixas de resultado) está no Pacote de Modelos — Modelo 13.

- **Carta para a Alta Gestão — estrutura recomendada**

Documento institucional curto apresentado ao dirigente máximo no início do trabalho de adequação. Tem 5 campos principais. Os textos abaixo são apenas EXEMPLOS — adaptar à realidade do órgão.

1. Destinatário

Identificação formal do dirigente máximo (Prefeito(a), Presidente, Reitor(a), conforme órgão)

2. Justificativa legal

Síntese das obrigações decorrentes da LGPD aplicáveis ao órgão — citação dos artigos relevantes (1º, 23-32, 41)

3. Riscos de não-cumprimento

Sanções administrativas, responsabilização civil em incidentes, repercussão midiática, apontamentos do TC e MP

4. Pedido concreto

Designação formal do Encarregado · Constituição do Comitê · Alocação de recursos · Inclusão na agenda estratégica

5. Assinatura

Responsável pela condução do trabalho (Encarregado, ou líder técnico-jurídico, na fase pré-designação)



Como aplicar na sua Instituição

- ▶ Repetir o Termômetro Institucional a cada 6 meses pra acompanhar a evolução real da maturidade.
- ▶ Apresentar a Carta da Alta Gestão em reunião de Comitê Gestor — não basta enviar por e-mail, é importante haver discussão e registro em ata.
- ▶ Construir um Plano de Comunicação Interna de LGPD: pílulas mensais por e-mail, banner na intranet, vídeo institucional curto. Vira parte do Programa Permanente de Educação em Privacidade.



Fase 1 — Formação das equipes de trabalho



Conteúdo institucional

A Fase 1 cumpre uma obrigação direta da LGPD: o Art. 41 determina ao controlador a indicação de um Encarregado pelo Tratamento de Dados Pessoais (DPO). No setor público, essa indicação deve ser feita por ato formal — Portaria, Decreto ou Despacho — publicado no diário oficial e com canal de contato divulgado ao cidadão.

A Resolução CD/ANPD nº 18/2024 detalha os critérios pra designação: perfil técnico-jurídico compatível, autonomia funcional, ausência de conflito de interesse e acesso direto à alta administração. A escolha não é livre — precisa de justificativa que demonstre aderência a esses critérios.

• Como proceder

- ▶ Identificar candidato com perfil técnico-jurídico compatível (não precisa ser advogado; precisa entender LGPD, segurança da informação e a realidade dos processos do órgão).
- ▶ Documentar a justificativa da escolha (vai constar no Ato de Designação).
- ▶ Cadastrar contatos do Encarregado: nome, e-mail institucional, telefone, endereço pra atendimento presencial. Esses dados são públicos por força do Art. 41 §1º.
- ▶ Designar Encarregado Substituto pra continuidade em férias/afastamento (recomendação da ANPD).
- ▶ Emitir Ato de Designação formal e publicá-lo no diário oficial.
- ▶ Divulgar os contatos do Encarregado no Aviso de Privacidade público e na intranet do órgão.

Erro comum

Designar o Encarregado verbalmente, sem ato formal publicado, é incumprimento direto da LGPD. Em fiscalização ANPD, a primeira pergunta é 'cadê o ato?'. Se não

tem, todas as defesas posteriores caem.



Modelos de referência

- **Ato de Designação — estrutura típica**

O Ato de Designação é o documento formal que cumpre o Art. 41 da LGPD.

Estrutura típica de Portaria/Decreto em órgão público brasileiro:

Cabeçalho

ATO DE DESIGNAÇÃO Nº MM/AAAA — (Designação do Encarregado pelo Tratamento de Dados Pessoais)

Ementa

Designa o Encarregado em cumprimento ao Art. 41 da Lei nº 13.709/2018

Considerandos

(a) Lei nº 13.709/2018 · (b) Resolução CD/ANPD nº 18/2024 · (c) necessidade de canal formal com ANPD e titulares

Art. 1º

Designa fulano(a) como Encarregado(a) — Parágrafo único: contatos (e-mail, telefone, endereço)

Art. 2º

Justificativa da escolha — perfil técnico-jurídico, autonomia, acesso à alta administração

Art. 3º

Atribuições conforme Art. 41 §2º da LGPD

Art. 4º

Vigência — entra em vigor na publicação

Assinatura

Autoridade máxima do órgão + ciência do designado(a)

- **Critérios da Resolução CD/ANPD nº 18/2024**

- ▶ Perfil técnico-jurídico compatível — não exige formação em Direito, exige domínio prático de LGPD
- ▶ Autonomia funcional — proteção contra retaliação por decisões técnicas
- ▶ Ausência de conflito de interesse — não deve ser auditado pela própria função
- ▶ Acesso direto à alta administração — sem intermediação burocrática
- ▶ Encarregado Substituto — recomendado pra continuidade em férias/afastamentos



Como aplicar na sua Instituição

- ▶ Publicar o Ato de Designação do Encarregado no Diário Oficial e arquivar a edição como prova documental.
- ▶ Constituir formalmente o Comitê de Privacidade por ato administrativo, com representantes das áreas-chave (TI, Jurídico, Comunicação, RH, áreas de negócio).
- ▶ Estabelecer calendário fixo de reuniões do Comitê (mensais no início, trimestrais quando consolidado).
- ▶ Divulgar os contatos do Encarregado em todos os canais externos do órgão: portal, redes sociais, materiais impressos, painéis físicos.



ETAPAS DO PGP • FASE 2

Fase 2 — Diagnóstico Inicial



Conteúdo institucional

A Fase 2 prepara o terreno pro mapeamento detalhado da Fase 3. Não é Inventário ainda — é o LEVANTAMENTO PRELIMINAR de onde a Instituição trata dados e quais processos entram primeiro na fila.

Em órgãos públicos, a tentação é tentar mapear TUDO de uma vez — o que afoga a equipe e atrasa entregas. A Resolução CD/ANPD nº 2/2022 traz critérios objetivos pra priorização: dados sensíveis, dados de crianças/adolescentes, larga escala, decisões automatizadas, alto impacto sobre os titulares. A Fase 2 aplica esses critérios pra definir quais 2-3 processos serão mapeados em detalhe primeiro.

• Como proceder

- ▶ Levantar a lista bruta de setores que tratam dados pessoais (Saúde, RH, Tributário, Ouvidoria, TI, Comunicação, etc.). Não é exaustivo — é varredura inicial.
- ▶ Para cada setor, identificar 1-2 processos críticos típicos (atendimento ao cidadão, folha de pagamento, sistema de prontuários, transmissão de sessão, etc.).
- ▶ Aplicar a Matriz de Priorização da Resolução nº 2/2022 a esses processos — pontuar por dados sensíveis, volume, vulnerabilidade dos titulares, etc.
- ▶ Selecionar os 2-3 processos mais críticos pra começar a Fase 3.
- ▶ Construir o Roadmap de 90 dias detalhando como os processos prioritários serão mapeados e o que segue depois.
- ▶ Acordar o cronograma com a Alta Gestão e formalizar.



Modelos de referência

• Levantamento de setores — exemplo ilustrativo

Lista típica de setores que tratam dados pessoais em um órgão municipal. Adaptar à estrutura específica da Instituição:

- ▶ Recursos Humanos — folha de pagamento, contratação, processos seletivos
- ▶ Atendimento ao Cidadão / Ouvidoria — manifestações, denúncias, reclamações
- ▶ Tributário — cadastro fiscal de contribuintes, IPTU/ISS
- ▶ Saúde — prontuários eletrônicos, agendamentos, programas de saúde
- ▶ Educação — matrículas, registros escolares, dados de responsáveis
- ▶ Assistência Social — cadastro de famílias, programas sociais
- ▶ Tecnologia da Informação — gestão de acessos, logs, sistemas
- ▶ Comunicação — mailing institucional, redes sociais, transmissões

• **Matriz de Priorização — Resolução CD/ANPD nº 2/2022**

Critérios pra priorizar quais processos entram primeiro no Inventário detalhado da Fase 3. Cada critério pontua em 3 níveis (1/2/3). Score final 0-18: 0-6 BAIXA, 7-12 MÉDIA, 13-18 ALTA prioridade.

 Volume de titulares afetados

Quantas pessoas têm dados tratados por este processo?

 Sensibilidade dos dados

Os dados tratados se enquadram no Art. 5º II da LGPD (sensíveis)?

 Vulnerabilidade dos titulares

Há tratamento de dados de crianças, adolescentes, idosos ou outros vulneráveis?

 Exposição pública dos dados

Os dados são publicizados ou compartilhados com público amplo?

 Uso de tecnologias inovadoras

Há IA, decisões automatizadas, biometria ou tecnologias emergentes?

 Compartilhamentos com terceiros

O processo envolve compartilhamento de dados com operadores ou outros controladores?

• **Roadmap de 90 dias — exemplo gerado automaticamente**

Cronograma sugerido pra os 90 dias seguintes ao início do trabalho — distribui as 7 Fases do PGP em 13 marcos semanais. Modelo abaixo serve como referência; adaptar prazos à capacidade operacional da Instituição.

Sem.

Fase

Atividade-chave

Entrega

1

Fase 1

Designação formal do Encarregado

Encarregado(a) formalmente designado(a) e divulgado(a)

2

Fase 1

Constituição do Comitê de Governança de Dados Pessoais

Comitê constituído e em operação

3

Fase 2

Levantamento preliminar de setores e processos

Lista priorizada de processos a serem mapeados

4

Fase 3

Inventário do Processo 1: Atendimento no Posto de Saúde Dr. Joaquim Bento

Inventário do Atendimento no Posto de Saúde Dr. Joaquim Bento aprovado pelo(a) Encarregado(a)

5

Fase 3

Inventário do Processo 2: Sistema de Contratação de Estagiários

Inventário do Sistema de Contratação de Estagiários aprovado pelo(a)
Encarregado(a)

6

Fase 3

Análise de Riscos dos 2 processos prioritários

Matriz de riscos aprovada + plano de mitigação inicial

7

Fase 4

GAP Analysis — diagnóstico de conformidade

GAP Analysis consolidado com score de conformidade

8

Fase 5

Plano de Ação consolidado

Plano de Ação institucional com cronograma e responsáveis

9

Fase 6

RIPD do processo mais crítico

RIPD aprovado e arquivado

10

Fase 6

Gestão de Terceiros + Canal de Direitos do Titular

Contratos com operadores em conformidade + canal DSR funcionando

11

Fase 6

Aviso de Privacidade institucional publicado

Aviso de Privacidade publicado e divulgado

12

Fase 7

Plano de Resposta a Incidentes (PRI)

PRI institucional aprovado e testado

13

Fase 7

Monitoramento contínuo + revisão do programa

Programa de Governança em Privacidade em operação contínua



Como aplicar na sua Instituição

- ▶ Atualizar a Matriz de Priorização semestralmente — processos mudam, novos sistemas entram, prioridades evoluem.
- ▶ Usar a Carta de Serviços do órgão como fonte de descoberta de processos: cada serviço listado vira potencialmente 1 processo a mapear.
- ▶ Acompanhar o cumprimento do Roadmap de 90 dias em reuniões mensais do Comitê de Privacidade.



A Carta de Serviços como fonte de descoberta de processos

Uma das maiores dificuldades das Instituições no início do PGP é a pergunta: "por onde começar o Inventário?". A resposta mais pragmática e eficiente está num documento que TODO órgão público brasileiro é obrigado a manter pela Lei nº 13.460/2017 (Código de Defesa do Usuário do Serviço Público): a Carta de Serviços.

A Carta de Serviços lista TODOS os serviços que o órgão presta ao cidadão — e cada serviço prestado envolve, quase invariavelmente, tratamento de dados pessoais por trás. Usá-la como ponto de partida do Inventário garante cobertura abrangente sem reinventar a roda.

- **Método prático em 5 passos**

- ▶ 1. Localizar a Carta de Serviços vigente — geralmente publicada no portal institucional ou na intranet. Se não houver, é tarefa anterior do órgão (obrigação legal antes mesmo da LGPD).
- ▶ 2. Listar todos os serviços oferecidos — atendimento ao cidadão, ouvidoria, programas sociais, alvarás, tributos, saúde, educação, cultura, etc. Para órgão pequeno, costuma haver 20-40 serviços; para órgãos médios, 80-150.
- ▶ 3. Para cada serviço, fazer 6 perguntas: (1) quais dados pessoais são coletados? (2) de quem? (cidadão? servidor? terceiro?) (3) com que finalidade? (4) base legal? (5) quanto tempo guardamos? (6) com quem compartilhamos?
- ▶ 4. Cada serviço onde houver tratamento de dados vira potencialmente UM processo no Inventário. Serviços muito similares (ex: vários alvarás com o mesmo fluxo) podem virar 1 processo único.
- ▶ 5. Priorizar os processos identificados aplicando a Matriz da Resolução CD/ANPD nº 2/2022 (volume, sensibilidade, vulneráveis, exposição, tecnologias, compartilhamentos). Começar pelos de maior pontuação.

• Exemplos típicos de mapeamento Carta → Inventário

Serviço na Carta: Atendimento na Unidade Básica de Saúde

Vira processo

Atendimento médico ambulatorial — Posto de Saúde

Dados típicos

Cadastrais (nome, CPF, endereço) + dados sensíveis de saúde (anamnese, prescrições, exames, prontuário eletrônico)

Base legal sugerida

Art. 7º III + Art. 11 II 'a' (execução de políticas públicas + tutela da saúde)

Serviço na Carta: Inscrição em programa social de transferência de renda

Vira processo

Gestão do programa de auxílio social municipal

Dados típicos

Cadastrais + composição familiar + renda + crianças e adolescentes (vulneráveis)

Base legal sugerida

Art. 7º III + Art. 14 (proteção da criança e adolescente)

Serviço na Carta: Manifestação na Ouvidoria

Vira processo

Atendimento ao Cidadão — Ouvidoria

Dados típicos

Cadastrais + conteúdo da manifestação (eventualmente dados sensíveis)

Base legal sugerida

Art. 7º II (Lei nº 13.460/2017)

Dica final

No app principal (lgpd-pgp), há recurso "Sugerir processos da Carta" que extrai automaticamente os serviços da página da Carta de Serviços do órgão e propõe processos pré-rascunhados pra revisão. Mesmo sem essa automação, o método manual leva 1-2 dias de trabalho e gera Inventário muito mais completo que partir do zero.



Fase 3 — Mapeamento e Análise de Riscos



Conteúdo institucional

Esta fase combina o mapeamento detalhado de todos os processos de tratamento de dados pessoais com a análise dos riscos associados a cada tratamento.

- **Parte 1: Mapeamento de Processos**

O mapeamento deve documentar para cada processo de tratamento:

- ▶ Quais dados pessoais são coletados
- ▶ Como são coletados (formulários, contratos, sistemas)
- ▶ Para que finalidade são utilizados
- ▶ Qual a base legal (consentimento, contrato, obrigação legal, etc.)
- ▶ Onde são armazenados
- ▶ Quem tem acesso a esses dados
- ▶ Por quanto tempo são mantidos
- ▶ Com quem são compartilhados
- ▶ Como são descartados

- **Parte 2: Análise de Riscos**

Para cada processo mapeado, avalie os riscos de segurança e privacidade:

- ▶ Riscos de vazamento ou acesso não autorizado
- ▶ Adequação das medidas de segurança existentes
- ▶ Vulnerabilidades técnicas e organizacionais
- ▶ Impacto potencial sobre os titulares em caso de incidente
- ▶ Riscos regulatórios e reputacionais

Importante

O mapeamento deve incluir TODOS os departamentos da Instituição. Cada área trata dados de forma diferente e todas devem estar em conformidade. A análise de riscos deve ser realizada para cada processo mapeado.

- **Resultado Esperado**

Ao final desta fase, a Instituição deve ter um Inventário de Dados completo e um Relatório de Análise de Riscos, documentando todo o ciclo de vida dos dados pessoais e os riscos associados a cada tratamento.

- **Como proceder**

A Fase 3 é onde a maioria dos órgãos públicos tropeça — não por falta de método, mas por subestimar o tamanho do mapeamento. Algumas orientações práticas pra esta fase no curso:

- **1. Comece pelos processos que mais expõem o cidadão**

Em Vegas, escolhemos 2 processos críticos por órgão pro jogo (Posto de Saúde + Estagiários para a Prefeitura · Tribuna Livre + Ouvidoria para a Câmara). Em um caso real, a recomendação é a mesma — comece pelos processos com dados sensíveis, dados de crianças, ou grande volume de cidadãos atendidos. A vitória rápida vem desses.

- **2. A ordem dentro de cada processo importa**

Não comece pela base legal — comece pelos TITULARES. A pergunta certa é: quem é o cidadão que entrega o dado? Crianças? Idosos? Pacientes? Esse 'quem' muda toda a análise depois: base legal especial, retenção mais curta, medidas de segurança reforçadas.

A ordem certa do Inventário

titulares → dados coletados → finalidade → base legal → retenção → compartilhamentos → medidas de segurança

- **3. Riscos são concretos, não abstratos**

Risco não é 'pode haver vazamento'. É 'se o pendrive com 2.300 prontuários sair daqui, esses pacientes sofrem chantagem, estigma, ou perdem emprego'. Conecte cada risco a uma consequência concreta pro titular — isso muda como o grupo posiciona o risco na matriz 3×3.

- **4. Aprovação pelo DPO é parte do método**

No app, o DPO APROVA ou DEVOLVE COM MOTIVO cada processo do Inventário. Devolver não é punição — é parte do método. Um motivo bem escrito na devolução vira aprendizado pro Contribuidor refazer.

- **5. Quem preenche o Inventário? 3 caminhos válidos**

A LGPD não prescreve QUEM preenche cada campo — exige apenas que o resultado final esteja sob responsabilidade do controlador (Art. 37 LGPD). Na realidade da implementação, 3 dinâmicas convivem nos órgãos públicos, e o app suporta as 3:

(a) DPO sozinho — quando o Encarregado conhece o processo o suficiente pra mapear sem apoio. Útil em processos simples ou quando o DPO tem origem técnica/jurídica no tema (ex: Encarregado da área de TI mapeando um sistema próprio). Vantagem: rapidez. Limite: depende do DPO ter informação atualizada — o que nem sempre é o caso.

(b) Contribuidor submete ao DPO — o Dono do processo (Sec. de Saúde, RH, Cerimonial, Ouvidoria...) preenche os campos técnicos, clica em "Submeter ao DPO", e o Encarregado revisa para aprovar ou devolver com observações. Esta é a dinâmica mais comum em órgãos públicos com áreas técnicas especializadas — preserva a autoridade do DPO sem exigir que ele saiba os detalhes de cada sistema da casa. É também a que o curso prático simula com maior ênfase.

(c) DPO + Contribuidor preenchem juntos — edição colaborativa em qualquer ordem (ambos os papéis abrem o mesmo formulário e vão complementando). Indicada pra processos com dados sensíveis, risco alto ou alto impacto institucional — quando o custo de um erro justifica a revisão a quatro mãos desde o primeiro rascunho.

Por que importa pedagogicamente

No curso desta turma, predomina o cenário (b) — Contribuidor submete ao DPO — porque é o que mais reflete a realidade do setor público. Mas tenha clareza: na sua instituição, vocês escolhem a dinâmica conforme o processo. O DPO não precisa fazer tudo sozinho, nem deve abdicar da palavra final. O que conta é o registro formal de aprovação no fim.



- **Inventário — 2 processos modelo**

Dois exemplos completos de processo no Inventário, com os 9 campos preenchidos. Use como referência da granularidade esperada na hora de mapear processos da sua Instituição:

- **Exemplo: Atendimento ao Cidadão — Ouvidoria**

Setor

Ouvidoria

Finalidade

Receber, processar e responder manifestações de cidadãos (reclamações, sugestões, denúncias, elogios e pedidos de informação) sobre serviços públicos prestados pelo órgão.

Base legal

Art. 7º, II (cumprimento de obrigação legal — Lei nº 13.460/2017, Código de Defesa do Usuário do Serviço Público) e Art. 7º, III (execução de políticas públicas).

Tipos de dados

Nome, CPF, e-mail, telefone, endereço, conteúdo da manifestação (pode incluir dados sensíveis quando o cidadão relata situação de saúde, opinião política ou orientação religiosa).

Dados sensíveis

Sim

Retenção

5 anos a partir do encerramento da manifestação (prazo prescricional padrão da Administração Pública). Manifestações encerradas com providência judicial seguem prazo processual específico.

Compartilhamento

Compartilhamento interno entre Ouvidoria e secretaria responsável pelo objeto da manifestação. Compartilhamento externo apenas mediante requisição legal (CGU, MP, Judiciário).

Medidas de segurança

Sistema de Ouvidoria com login individualizado por servidor, registro de acessos, criptografia em trânsito, backup criptografado. Acesso restrito ao núcleo da Ouvidoria + servidor designado por secretaria.

- **Exemplo: Folha de Pagamento — Servidores**

Setor

RH

Finalidade

Processar mensalmente a folha de pagamento dos servidores (ativos, inativos e pensionistas), incluindo cálculo de vencimentos, descontos legais, contribuições previdenciárias e tributos.

Base legal

Art. 7º, II (cumprimento de obrigação legal — Estatuto dos Servidores, CLT, legislação previdenciária e tributária).

Tipos de dados

Nome, CPF, RG, PIS/PASEP, conta bancária, dados de dependentes (incluindo crianças), conta de FGTS, descontos judiciais (pensão alimentícia), dados de saúde (atestados, licenças médicas).

Dados sensíveis

Sim

Retenção

75 anos para fins previdenciários (legislação previdenciária federal). Atestados médicos seguem prazo de 5 anos após o evento (resoluções CFM).

Compartilhamento

Receita Federal, INSS, Tribunal de Contas, sindicatos (para descontos autorizados), instituição bancária pagadora.

Medidas de segurança

Sistema de folha (SIAPE ou equivalente) com login individualizado, segregação de função entre quem cadastra e quem aprova, logs auditáveis, backup criptografado em data center próprio ou contratado com cláusulas LGPD.

- **Análise de Riscos — 2 riscos modelo (matriz P × I)**

Dois exemplos de risco mapeado pra os processos modelo acima, com severidade (Probabilidade × Impacto) e plano de mitigação:

- **Exemplo: Vazamento de dados sensíveis por compartilhamento indevido**

Categoria

Confidencialidade

Severidade

Probabilidade Média × Impacto Alto = ALTO

Descrição

Servidor da Ouvidoria encaminha por e-mail comum (sem criptografia) uma manifestação que contém relato de problema de saúde do cidadão, para colega de outra secretaria. O e-mail é interceptado, ou o destinatário compartilha o conteúdo sem autorização.

Plano de mitigação

Treinamento sobre dados sensíveis e canais seguros de comunicação interna; substituição de e-mail por sistema corporativo com controle de acesso; checklist no fluxo de encaminhamento que exija anonimização de dados sensíveis quando possível.

- **Exemplo: Acesso indevido à folha de pagamento por servidor não autorizado**

Categoria

Princípio da finalidade / necessidade

Severidade

Probabilidade Alta × Impacto Médio = ALTO

Descrição

Servidor com acesso amplo ao sistema de folha consulta dados de colegas por curiosidade ou pra obter informação sobre processos sigilosos (pensões judiciais, descontos compulsórios), sem que isso seja necessário ao exercício de sua função.

Plano de mitigação

Revisão dos perfis de acesso no sistema (princípio do menor privilégio); ativação de logs de consulta por CPF; auditoria periódica das consultas; treinamento + termo de responsabilidade individual.



Como aplicar na sua Instituição

- ▶ Estender o Inventário gradualmente pra TODOS os setores — meta razoável: 5 processos novos mapeados por trimestre.
- ▶ Submeter cada processo à aprovação formal do Encarregado antes de declarar como 'consolidado'.
- ▶ Reavaliar a matriz de Risco anualmente — riscos mudam à medida que sistemas, terceiros e contextos mudam.
- ▶ Documentar mitigações implementadas e o efeito mensurável delas no nível de risco residual.



ETAPAS DO PGP • FASE 4

Fase 4 — GAP Analysis



Conteúdo institucional

Com base no mapeamento e análise de riscos da Fase 3, esta etapa identifica as lacunas (gaps) entre o estado atual da Instituição e os requisitos estabelecidos pela LGPD e boas práticas de proteção de dados.

- **O que é GAP Analysis?**

É uma análise sistemática que compara o "estado atual" (AS-IS) com o "estado desejado" (TO-BE) de conformidade, identificando todas as lacunas que precisam ser endereçadas.

- **Áreas Avaliadas**

- ▶ Bases Legais: todos os tratamentos possuem base legal adequada e documentada?
- ▶ Transparência: as políticas e avisos de privacidade são completos e acessíveis?
- ▶ Direitos dos Titulares: há processos para atender às solicitações (Arts. 18 e 19)?
- ▶ Segurança: as medidas de segurança são adequadas aos riscos?
- ▶ Contratos: fornecedores e parceiros têm cláusulas adequadas (Art. 39)?
- ▶ Governança: há políticas, procedimentos e documentação adequados?
- ▶ Retenção: períodos de retenção estão definidos e respeitados?
- ▶ Treinamento: colaboradores estão capacitados e conscientizados?

- **Priorização de Gaps**

As lacunas devem ser priorizadas considerando:

- ▶ Criticidade do risco associado
- ▶ Impacto potencial sobre os titulares
- ▶ Exposição a sanções regulatórias

- ▶ Esforço e custo de correção
- ▶ Dependências entre gaps

Atenção

Esta análise é fundamental para priorizar as ações corretivas que serão implementadas na próxima fase (Plano de Ação). Seja completo e objetivo na identificação dos gaps, pois eles guiarão todo o plano de ação.

- **Resultado Esperado**

Ao final desta fase, a Instituição deve ter um Relatório de GAP Analysis completo, com todas as lacunas identificadas, classificadas e priorizadas, servindo de base para o Plano de Ação da próxima fase.

- **Como proceder**

GAP Analysis é a fase que SEPARA órgãos honestos dos que estão fingindo. A regra é simples: medir maturidade real vale mais que parecer maduro. Algumas orientações pra esta fase no curso:

- **1. ADERENTE significa praticado, não previsto**

A pegadinha mais comum: marcar ADERENTE porque "existe uma política no papel". Não. ADERENTE é "está sendo PRATICADO de verdade, posso provar com um caso real dos últimos 12 meses". Política guardada em pasta de PDF que ninguém abre não é aderência — é decoração.

Régua honesta de classificação

ADERENTE = praticado E documentado · PARCIAL = praticado mas inconsistente OU documentado mas não praticado · NÃO ADERENTE = não praticado, mesmo que esteja no papel

- **2. No curso, o pacote é enxuto — 10 controles**

Em uma adequação real, o GAP completo tem 119 controles em 28 domínios. Pra o jogo de 3h, curamos 10 controles que cobrem 5 áreas (Governança, Bases Legais, Direitos, Segurança, Incidentes) com 2 controles por área. A lição não é a profundidade — é o MÉTODO de classificar com honestidade.

- **3. A linha de justificativa importa mais que a classificação**

"Não aderente" sem justificativa é confissão sem ação. "Não aderente — falta política de senhas formal; usuários compartilham logins administrativos" é insumo direto pro Plano de Ação. Capriche na justificativa: ela vira a primeira coluna do que o Plano vai resolver.

- **4. Score baixo não é fracasso — é diagnóstico**

Score 30% honesto vale 10x mais que score 90% inflado. A ANPD não pune órgão por baixa maturidade declarada — pune por descumprimento sem reconhecimento. O órgão que documenta suas lacunas demonstra governança ativa; quem mascara, vira manchete quando algo dá errado.

- **5. Apoio de outros setores é parte do método**

No app, controles podem ficar marcados como "APOIO PENDENTE" com indicação do setor solicitado (Procuradoria, TI, RH...). É honestidade institucional: nem todo controle o DPO consegue avaliar sozinho. No curso, observe quais grupos pedem apoio — é sinal de maturidade pedagógica, não de fraqueza.



Modelos de referência

- **Aplicação do GAP — 3 controles modelo**

Para cada controle do catálogo GAP, a Instituição se classifica em ADERENTE / PARCIAL / NÃO ADERENTE com justificativa. Exemplos:

- **Encarregado (DPO) designado por ato formal e publicado**

Área

DPO/Encarregado

Classificação

Aderente — controle implementado e em funcionamento

Justificativa

Encarregado designado por Portaria publicada no diário oficial. Contatos divulgados no Aviso de Privacidade público do portal institucional.

- **Inventário de processos atualizado nos últimos 12 meses**

Área

Inventário

Classificação

Parcial — controle existe mas não está consolidado

Justificativa

Inventário foi iniciado e cobre os 2 processos críticos identificados na Fase 2, mas ainda não foi estendido para a totalidade dos setores. Revisão programada pra o próximo ciclo.

- **Contratos com operadores (terceirizados) contêm cláusulas LGPD obrigatórias (Art. 39)**

Área

Gestão de Operadores

Classificação

Não aderente — controle ausente ou inadequado

Justificativa

Levantamento dos contratos vigentes em curso. Maioria dos contratos com operadores foi celebrada antes da LGPD entrar em vigor — necessário promover aditamento com cláusulas mínimas de proteção de dados.



Como aplicar na sua Instituição

- ▶ Aprofundar a Análise de GAP estendendo dos controles do curso pra o catálogo completo da LGPD (Guia ANPD, Resolução nº 2/2022, ABNT 27701).
- ▶ Cada controle NÃO ADERENTE deve virar 1 ação no Plano com responsável e prazo — sem ação, não há fechamento de GAP.
- ▶ Repetir o GAP anualmente como instrumento de monitoramento da maturidade.



Fase 5 — Plano de Ação e Adequação



Conteúdo institucional

Com base nos riscos e lacunas identificadas nas Fases 3 e 4, esta etapa consiste em criar um plano de ação detalhado para corrigir as não conformidades e implementar as melhorias necessárias para adequação à LGPD.

- **Elementos do Plano de Ação**

- ▶ Priorização: organize as ações por criticidade e urgência
- ▶ Responsáveis: defina quem será responsável por cada ação
- ▶ Prazos: estabeleça cronograma realista para implementação
- ▶ Recursos: identifique os recursos necessários (financeiros, humanos, tecnológicos)
- ▶ Indicadores: defina como medir o sucesso de cada ação

- **Ações Típicas**

- ▶ Criação/atualização de Políticas de Privacidade
- ▶ Adequação de contratos e termos de uso
- ▶ Implementação de medidas de segurança técnicas
- ▶ Treinamento de servidores e colaboradores
- ▶ Adequação de processos de coleta e consentimento
- ▶ Criação de procedimentos para atendimento aos direitos dos titulares
- ▶ Implementação de gestão de incidentes

Dica de accountability

Mantenha registro detalhado de todas as ações implementadas. Esta documentação será importante para demonstrar conformidade e o princípio da accountability (prestação de contas) exigido pela LGPD.

- **Como proceder**

O Plano de Ação é o coração do PGP — onde o diagnóstico vira ação concreta. É também onde a maioria dos órgãos públicos tropeça: faz um Plano belíssimo, apresenta pro Comitê com powerpoint elegante, e depois ele vira PDF de gaveta. Pra essa fase no curso, algumas orientações:

- **1. Plano é matéria-prima, não enfeite**

O Plano não é entregue PRA ser bonito — é entregue PRA ser executado. Cada ação deve ter responsável NOMEADO (não 'a área de TI'), prazo CONCRETO (não 'a definir') e indicador MEDÍVEL (não 'melhorar a segurança'). Se não cabe em uma linha do estilo 'Joana cria a política X até 15/abr e a medida é X% de servidores treinados', a ação está mal formulada.

- **2. Importação automática do que já existe**

No app, o botão 'Auto-importar do PGP' puxa de um clique: cada controle NÃO ADERENTE do GAP vira uma ação no Plano, e cada risco com plano de mitigação vira outra. Você não digita ação a partir do zero — você EDITA o que o app gerou da Fase 4. Isso resolve a dor 'não sei por onde começar'.

Fontes que alimentam o Plano

GAP Não Aderente / Parcial / Ação Planejada · Riscos com mitigação · Diagnóstico de Privacidade · Pendências do Inventário. Tudo entra como uma linha editável.

- **3. Priorização honesta: 4 critérios, sem furada**

Pra ordenar o Plano, use SEMPRE os mesmos 4 critérios: (a) risco ao titular se nada for feito, (b) prazo legal exigido pela LGPD, (c) esforço de execução, (d) dependências entre ações (uma destrava outra?). 'Vontade política do gestor' não entra — porque muda com a próxima eleição.

- **4. Acompanhamento mata o Plano de Gaveta**

Plano de Ação sem reunião quinzenal de acompanhamento vira PDF de gaveta em ~60 dias. Comprove: agende reuniões CURTAS (15 min) com os responsáveis quinzenalmente, projete o status do app no telão, e cobre evidência (não 'tá em andamento' — print, ata, link).

- **5. Conexão com a Fase 6 é direta**

As ações do Plano não viram conformidade por si — viram quando EXECUTADAS na Fase 6 (Políticas, RIPD, Terceiros, Aviso de Privacidade). O Plano é o contrato; a Fase 6 é a entrega. Se o Plano marca 'criar Aviso de Privacidade até X' e na Fase 6 o Aviso fica em rascunho 6 meses, é o Plano que está falhando — não a Fase 6.



Modelos de referência

- **Plano de Ação — 3 ações modelo**

Cada controle GAP não-aderente e cada risco alto deve virar uma ação no Plano com responsável, prazo e prioridade. Exemplos:

Ação

Responsável

Prazo

Prioridade

Status

Origem

Promover aditivo contratual com cláusulas LGPD em todos os contratos vigentes celebrados antes de 2020

Procuradoria Jurídica + Administrativo

05/09/2026

ALTA

Aberta

GAP

Implementar segregação de função no sistema de folha (perfil 'cadastrar' separado de 'aprovar')

TI + RH

08/08/2026

ALTA

Aberta

RISCO

Capacitação anual obrigatória em LGPD pra todos os servidores que tratam dados pessoais

RH + DPO

03/10/2026

MEDIA

Aberta

GAP



Como aplicar na sua Instituição

- ▶ Formalizar o Programa de Governança em Privacidade (PGP) como Política institucional aprovada pelo dirigente máximo.
- ▶ Estabelecer ciclo de revisão anual do PGP com relatório formal ao gabinete.
- ▶ Vincular o orçamento do PGP ao planejamento estratégico do órgão (PPA/LDO/LOA).



Modelo — Política do Programa de Governança em Privacidade

Documento mater do PGP. Aprovado por ato formal do dirigente máximo do órgão. Cita os demais instrumentos (Inventário, Riscos, GAP, Plano, RIPDs, Operadores, DSR, Aviso, PRI) como anexos vinculados.

• 1. Objetivo

Esta Política estabelece o Programa de Governança em Privacidade (PGP) de **[NOME DA INSTITUIÇÃO]**, em cumprimento à Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais (LGPD), regulamentando o tratamento de dados pessoais no âmbito de suas atividades.

• 2. Abrangência

Aplica-se a todas as unidades, servidores, estagiários, terceirizados e demais agentes que, no exercício de funções vinculadas a **[NOME DA INSTITUIÇÃO]**, realizem tratamento de dados pessoais — sob qualquer forma (digital ou física), sob qualquer base legal.

- **3. Princípios**

O tratamento de dados pessoais observa os princípios do Art. 6º da LGPD: finalidade, adequação, necessidade, livre acesso, qualidade dos dados, transparência, segurança, prevenção, não discriminação e responsabilização. Esses princípios são parâmetros obrigatórios pra todas as decisões operacionais.

- **4. Governança**

O PGP é conduzido pelo Encarregado pelo Tratamento de Dados Pessoais (DPO), designado por ato formal (Art. 41 LGPD), com apoio do Comitê de Privacidade — instância multidisciplinar com representantes das áreas de TI, Jurídico, Comunicação, RH e áreas de negócio. O Comitê reúne-se **[PERIODICIDADE]** e delibera sobre decisões estratégicas.

- **5. Instrumentos do PGP**

Integram o PGP, como anexos vinculados, os seguintes instrumentos: (a) Inventário de Tratamentos de Dados Pessoais; (b) Análise de Riscos de Privacidade; (c) Análise de Conformidade (GAP); (d) Plano de Ação; (e) Relatórios de Impacto à Proteção de Dados (RIPD) dos processos de alto risco; (f) Cadastro de Operadores com cláusulas LGPD; (g) Canal e procedimento de exercício de Direitos do Titular (DSR); (h) Aviso de Privacidade público; (i) Plano de Resposta a Incidentes (PRI). Esses instrumentos são revisados **[PERIODICIDADE]**.

- **6. Responsabilidades**

(a) Dirigente máximo: aprova o PGP, garante recursos, responde por sanções (Art. 52 LGPD); (b) Encarregado: conduz operacionalmente, aceita reclamações, comunica-se com ANPD e titulares; (c) Comitê: delibera estrategicamente; (d) Gestores de área: aplicam as orientações nas operações; (e) Servidores: cumprem as políticas, reportam incidentes; (f) Operadores: cumprem as cláusulas LGPD dos contratos.

- **7. Revisão e atualização**

Esta Política é revisada **[PERIODICIDADE – recomendado anualmente]** ou antes, caso haja: (a) alteração legislativa; (b) decisão da ANPD com efeito sobre o PGP; (c) incidente de severidade ALTA ou CRÍTICA; (d) reorganização institucional relevante.

- **8. Vigência**

Esta Política entra em vigor na data de sua publicação no diário oficial e revoga disposições em contrário.



ETAPAS DO PGP • FASE 6

Fase 6 — Execução



Conteúdo institucional

A Fase 6 marca o momento de colocar em prática tudo o que foi planejado nas fases anteriores. É onde a adequação à LGPD sai do papel e se torna realidade operacional na Instituição.

• Principais Objetivos

- ▶ Implementar Políticas e Documentação — políticas de privacidade externas e internas, POPs, contratos adequados e avisos de privacidade conforme planejado
- ▶ Executar Medidas de Segurança — controles técnicos e organizacionais identificados na análise de riscos: criptografia, controles de acesso, logs de auditoria, backups
- ▶ Adequar Processos Operacionais — coleta de dados, gestão de consentimentos, atendimento aos direitos dos titulares e resposta a incidentes
- ▶ Realizar Treinamentos e Conscientização — programa pra todos os servidores (geral e específico por área)
- ▶ Registrar Evidências de Compliance — documentar implementações e arquivar evidências do princípio da accountability

Ponto de atenção

Esta fase exige coordenação entre múltiplas áreas da Instituição. O DPO deve atuar como facilitador, garantindo que todas as ações do Plano de Ação sejam executadas dentro dos prazos estabelecidos e com a qualidade necessária.

Resultado esperado

Ao final desta fase, a Instituição deve ter todas as políticas, procedimentos e medidas de segurança operacionais, com equipes treinadas e conscientes de suas responsabilidades na proteção de dados pessoais.

• Como proceder

A Fase 6 é a maior do PGP em volume de entrega — onde RIPD, Aviso, Terceiros, DSR, Políticas e Capacitação acontecem em paralelo. Aqui o DPO deixa de ser apenas ESCRITOR e vira REGENTE: o trabalho dele é fazer áreas convergirem. Algumas orientações práticas:

- **1. A ORDEM importa: RIPD → Terceiros → DSR → Aviso**

O Aviso de Privacidade é uma SÍNTESE pública — depende do RIPD (Seção 3 do Aviso puxa dele), da lista de Terceiros (Seção 7 puxa dela) e do canal DSR (Seção 11 puxa dele). Grupos que pulam direto pro Aviso produzem documento vago, cheio de promessa vazia. No app, o quadro "Pré-requisitos da Missão 4a" no topo da tela de Aviso mostra exatamente o que falta antes de publicar.

Sequência canônica

RIPD do processo crítico → 1-2 Operadores com cláusulas LGPD → Canal DSR estruturado → Aviso de Privacidade (12 seções ANPD)

- **2. Conteúdo NÃO se inventa — vem das fases anteriores**

Cada documento da Fase 6 tem fonte de dados em uma fase anterior: o RIPD bebe do Inventário (Fase 3) e da Análise de Riscos (Fase 3); o Aviso bebe do RIPD; as Políticas bebem do Plano de Ação (Fase 5). No app, o botão 'Auto-preencher do PGP' faz isso automaticamente — você revisa em vez de digitar do zero.

- **3. Política de Privacidade externa vs. Política Interna**

São DOIS documentos com públicos diferentes. A externa (no site) é pro CIDADÃO — linguagem simples, 12 seções ANPD, fala dos direitos dele. A interna é pros SERVIDORES — fala das responsabilidades do dia a dia, do que fazer ao detectar um incidente, das regras de acesso e descarte. Não confundir.

- **4. Terceiros que tratam dados: a maior dor invisível**

Quase todo órgão tem dezenas de operadores (empresa de tecnologia, lab terceirizado, empresa de RH, escritório de advocacia, gráfica, transportadora...) que tratam dados pessoais por conta da Instituição. Cada um precisa de DPA (Data Processing Agreement) com cláusulas específicas (Art. 39 LGPD). Sem isso, em caso de incidente, a responsabilização pode vir 100% pra Instituição.

- **5. Direitos do Titular: 15 dias úteis é prazo curto**

Quando um cidadão pede 'me mostra todos os dados que vocês têm sobre mim' (Art. 18 II), você tem 15 dias úteis pra responder. Sem canal estruturado (formulário + fluxo interno + responsável + monitoramento de prazo), o prazo estoura no primeiro pedido sério. O canal DSR do app já vem com fluxo padrão — vocês só precisam definir QUEM responde e EM QUANTO TEMPO internamente.

- **6. Treinamento: separar 'sensibilização' de 'capacitação'**

Sensibilização (1-2h) é pra TODO servidor — entender o que é dado pessoal, por que importa, o que fazer se descobrir um vazamento. Capacitação (4-8h) é pra QUEM TRATA dados todo dia — RH, atendimento, ouvidoria, TI. São treinamentos DIFERENTES, com públicos diferentes. Misturar os dois afoga o detalhe e não satisfaz nenhum dos públicos.



Modelos de referência

- **RIPD — estrutura completa em 8 seções**

Relatório de Impacto à Proteção de Dados (Art. 38 LGPD). Obrigatório pros processos de alto risco. Estrutura recomendada pela ANPD:

Processo do exemplo: Folha de Pagamento — Servidores

1. Identificação do Controlador e do Encarregado

Controlador: a Instituição (qualificada no Aviso de Privacidade). Encarregado: nome do DPO designado por ato formal, contatos disponíveis no Aviso de Privacidade público. Operadores envolvidos: sistema de folha contratado (SIAPE ou equivalente), instituição bancária pagadora.

2. Descrição do tratamento e finalidades

Processamento mensal da folha de pagamento de servidores ativos, inativos e pensionistas. Finalidade: cumprimento de obrigação legal (pagamento de vencimentos e recolhimento de tributos/contribuições previdenciárias). Categorias de titulares: servidores efetivos, comissionados, terceirizados sob a Administração, aposentados, pensionistas e dependentes.

3. Necessidade e proporcionalidade

Os dados tratados são os estritamente necessários ao cálculo da remuneração, retenções fiscais, contribuições previdenciárias e identificação dos beneficiários.

Dados de saúde (atestados, licenças) são coletados apenas quando há registro de afastamento e descartados ao final do prazo legal.

4. Riscos identificados aos direitos dos titulares

(1) Acesso indevido por servidores sem necessidade funcional. (2) Vazamento de informações sensíveis (saúde, descontos judiciais). (3) Erro de cadastro com impacto financeiro pro servidor.

5. Medidas de segurança e mitigação

Sistema com login individualizado, segregação de função (cadastra ≠ aprova), logs auditáveis com retenção mínima de 6 meses, backup criptografado, contrato com o operador do sistema com cláusulas LGPD, treinamento anual obrigatório da equipe.

6. Mecanismos pra exercício de direitos dos titulares

Servidor pode solicitar acesso, correção, anonimização ou portabilidade dos seus dados pelo canal DSR do órgão (e-mail/formulário público). Prazo de resposta: 15 dias úteis (Art. 19, II LGPD).

7. Decisão e responsabilidades

O tratamento é necessário e proporcional. Medidas de mitigação implementadas reduzem os riscos identificados a nível aceitável. Aprovado pelo Encarregado em conjunto com Secretaria de Administração.

8. Revisão e atualização

Este RIPD será revisado a cada 12 meses ou antes, caso haja mudança significativa no fluxo (novo sistema, novo operador, alteração legislativa).

• Operadores — exemplo de cadastro

Todos os terceiros que tratam dados pessoais em nome do controlador (operadores) devem ser cadastrados com contratos contendo as cláusulas LGPD do Art. 39. Exemplo:

• Exemplo: Empresa Hipotética de Tecnologia LTDA

CNPJ

00.000.000/0001-00

Serviço prestado

Hospedagem do sistema interno de ouvidoria (SaaS)

Papel

OPERADOR

Contrato nº

045/2024

Objeto

Hospedagem em nuvem do sistema de ouvidoria, com SLA de disponibilidade e plano de backup criptografado.

Cláusulas LGPD

Sim

Nível de risco

MEDIO

- **Canal DSR — exemplo de solicitação atendida**

Toda Instituição precisa de canal funcional pra exercício de Direitos do Titular (Art. 18 LGPD). Resposta em até 15 dias úteis (Art. 19 II). Exemplo de registro:

- **Exemplo: ACESSO — Cidadão hipotético**

Contato do titular

[\[email protected\]](#)

Status

Respondida

Descrição

Solicitação de cópia das informações que a Instituição tem registradas sobre o titular, especialmente referentes a manifestações enviadas à Ouvidoria no último ano.

Resposta

Encaminhada cópia do extrato de manifestações registradas em nome do titular, com tarja em dados de terceiros mencionados nas manifestações. Prazo cumprido: 8 dias úteis.

- **Aviso de Privacidade — conteúdo recomendado**

Aviso de Privacidade contendo: identificação do controlador e do Encarregado, finalidades de tratamento por categoria de dados, bases legais, formas de exercer direitos do titular (canal DSR), prazos de retenção e medidas gerais de segurança. Publicado no portal externo em página acessível em até 2 cliques a partir da home, com data da última atualização visível.



Como aplicar na sua Instituição

- ▶ Garantir que todos os processos do Inventário com risco alto tenham RIPD elaborado e aprovado.
 - ▶ Promover aditamento contratual com cláusulas LGPD em todos os contratos vigentes com operadores.
 - ▶ Divulgar o canal DSR em todos os pontos de contato com o cidadão (portal, atendimento presencial, materiais físicos).
 - ▶ Manter o Aviso de Privacidade público atualizado a cada mudança significativa de tratamento.
 - ▶ Documentar e treinar a equipe nas políticas de retenção e anonimização.
-



Modelo — Cláusulas LGPD para contratos com operadores

Cláusulas mínimas obrigatórias (Art. 39 LGPD) para inclusão em contratos com terceiros que tratam dados pessoais em nome da Instituição (operadores). Para contratos vigentes celebrados antes de 2020, promover aditamento. Para contratos novos, incluir desde a redação.

Cláusula 1 — Objeto do tratamento

O OPERADOR realizará tratamento de dados pessoais exclusivamente para os fins descritos no objeto principal deste contrato, ficando vedado qualquer tratamento estranho a esse escopo, salvo expressa autorização prévia e por escrito da CONTRATANTE.

Cláusula 2 — Segurança e confidencialidade

O OPERADOR adotará medidas técnicas e administrativas adequadas para proteger os dados pessoais contra acessos não autorizados, perdas acidentais, alterações indevidas ou divulgação inadequada, em conformidade com os Arts. 46 a 49 da LGPD.

Cláusula 3 — Comunicação de incidentes

O OPERADOR comunicará à CONTRATANTE, imediatamente após o conhecimento e em prazo não superior a 24 (vinte e quatro) horas, qualquer incidente de segurança envolvendo dados pessoais sob seu tratamento, fornecendo as informações necessárias para subsidiar a comunicação à ANPD e aos titulares afetados.

Cláusula 4 — Subcontratação

O OPERADOR não subcontratará terceiros para o tratamento dos dados pessoais sem prévia autorização escrita da CONTRATANTE. Em caso de autorização, o sub-operador assumirá as mesmas obrigações deste contrato por meio de instrumento escrito.

Cláusula 5 — Direitos dos titulares

O OPERADOR auxiliará a CONTRATANTE no atendimento das solicitações dos titulares de dados (Art. 18 LGPD), em prazo não superior a 5 (cinco) dias úteis a contar da requisição.

Cláusula 6 — Retenção e devolução/destruição

Encerrada a relação contratual, o OPERADOR devolverá à CONTRATANTE ou destruirá, conforme orientação desta, todos os dados pessoais sob seu tratamento, em prazo não superior a 30 (trinta) dias, salvo determinação legal em contrário.

Cláusula 7 — Auditoria

A CONTRATANTE poderá, mediante aviso prévio de 15 dias úteis, realizar auditoria das medidas de segurança implementadas pelo OPERADOR, diretamente ou por terceiro independente.

Cláusula 8 — Responsabilidade

O OPERADOR responde civilmente pelos danos decorrentes do descumprimento das obrigações deste contrato, nos termos do Art. 42 da LGPD, sem prejuízo das sanções administrativas e judiciais cabíveis.



Modelo — Política de Retenção e Descarte de Dados Pessoais

A LGPD exige (Art. 16) que os dados pessoais sejam eliminados após o término do tratamento, salvo hipóteses específicas. Esta política define prazos por categoria de dado e procedimento de descarte seguro.

1. PRINCÍPIO GERAL — Os dados pessoais não devem ser mantidos por tempo superior ao necessário para o cumprimento da finalidade. Findo o tratamento, eliminar, anonimizar ou justificar a retenção em hipótese legal específica.

2. HIPÓTESES QUE AUTORIZAM RETENÇÃO (Art. 16 LGPD) — (a) cumprimento de obrigação legal ou regulatória; (b) estudo por órgão de pesquisa (com anonimização sempre que possível); (c) transferência a terceiro respeitada a Lei; (d) uso exclusivo do controlador, com anonimização.

3. PRAZOS POR CATEGORIA (parâmetros típicos do setor público):

- Dados de servidores ativos — durante o vínculo + prazo previdenciário (até 75 anos para fins de aposentadoria/pensão).
- Dados de servidores inativos / pensionistas — durante o pagamento de benefícios + prazos previdenciários aplicáveis.
- Dados de candidatos não selecionados em concursos / seleções — 1 ano após o término da validade do edital.
- Atendimento ao cidadão / Ouvidoria — 5 anos após o encerramento (prazo prescricional padrão).
- Dados de saúde (prontuários) — 20 anos da última consulta (CFM Resolução 1.821/2007 e correlatas).
- Dados fiscais / tributários — prazos da legislação tributária (geralmente 5 anos).
- Logs de acesso a sistemas — 6 meses a 5 anos conforme criticidade do sistema.
- Imagens de CFTV — 30 a 90 dias, salvo investigação em curso.
- Dados de licitantes não vencedores — 5 anos após o encerramento do certame (legislação licitatória).

4. PROCEDIMENTO DE DESCARTE — Documental: fragmentação ou incineração com registro. Digital: exclusão lógica + sobrescrita ou descarte físico do meio. Em

todos os casos, lavrar termo de descarte com data, responsável e categoria descartada.

5. ANONIMIZAÇÃO COMO ALTERNATIVA — Quando viável, anonimizar em vez de descartar (Art. 12 LGPD) — dado anonimizado sai do escopo da LGPD. Anonimização precisa ser irreversível (não basta pseudonimização).

6. REVISÃO ANUAL — Esta política é revisada anualmente, especialmente para adequar prazos a alterações legislativas e novos sistemas implantados.



Modelo — Termo de Consentimento do Titular

Modelo a usar nos casos específicos em que a base legal apropriada é o consentimento (Art. 7º I ou Art. 11 I LGPD). Importante: no Setor Público, consentimento é base legal EXCEPCIONAL — a regra é Art. 7º II (obrigação legal) ou Art. 7º III (execução de políticas públicas). Use consentimento APENAS quando o tratamento for facultativo do ponto de vista do cidadão (ex: cadastro voluntário em newsletter, autorização para uso de imagem em material promocional).

[NOME DA INSTITUIÇÃO], inscrita no CNPJ sob nº **[XXX]**, com sede em **[ENDEREÇO]**, na qualidade de Controlador (Art. 5º VI LGPD), solicita o consentimento de **[NOME DO TITULAR]** para o tratamento dos seguintes dados pessoais:

DADOS TRATADOS: **[lista específica – ex: nome, e-mail, telefone, imagem]**

FINALIDADE: **[específica – ex: envio de informativo institucional sobre eventos culturais]**

PRAZO DE RETENÇÃO: **[específico – ex: até que o titular solicite descadastro]**

COMPARTILHAMENTOS: **[se houver – ex: nenhum / com a empresa contratada para hospedagem do mailing]**

DIREITOS DO TITULAR: o titular pode, a qualquer tempo, revogar este consentimento e exercer os direitos do Art. 18 da LGPD (acesso, correção, anonimização, eliminação, portabilidade, oposição, informações sobre compartilhamento), pelo canal: **[E-MAIL DO ENCARREGADO]**.

DECLARAÇÃO: declaro ter sido informado(a) sobre o tratamento dos meus dados pessoais e concordo livremente, de forma específica e inequívoca (Art. 5º XII LGPD), com o tratamento descrito acima.

Local, data: _____

Assinatura do(a) titular: _____

Atenção

ATENÇÃO: NÃO usar consentimento para tratamento obrigatório de cadastro de cidadão atendido por serviço público — nesse caso a base legal correta é o Art. 7º II ou III. Consentimento exige possibilidade REAL de recusa sem prejuízo do atendimento. Consentimento marcado por padrão (opt-out) é inválido (Art. 8º).



Fase 7 — Monitoramento Contínuo e Melhoria



Conteúdo institucional

A conformidade com a LGPD não é um projeto com início, meio e fim, mas um processo contínuo. Esta última fase estabelece os mecanismos de monitoramento, auditoria e melhoria contínua do programa de governança de dados.

- **Atividades de Monitoramento**

- ▶ Auditorias Periódicas: internas e/ou externas para verificar conformidade
- ▶ Indicadores de Performance (KPIs): métricas para medir eficácia do programa
- ▶ Revisão de Políticas: atualização periódica da documentação
- ▶ Gestão de Incidentes: acompanhamento e análise de eventos de segurança
- ▶ Avaliação de Fornecedores: verificação contínua de operadores
- ▶ Atualização Legislativa: acompanhamento de mudanças na legislação

- **Indicadores Sugeridos**

- ▶ Tempo médio de resposta a solicitações de titulares (meta: < 15 dias úteis)
- ▶ Número de incidentes de segurança reportados (e prazo de comunicação à ANPD)
- ▶ Percentual de servidores treinados em LGPD
- ▶ Índice de conformidade em auditorias
- ▶ Tempo médio para correção de não conformidades
- ▶ Número de RIPDs realizados

- **Melhoria Contínua**

Com base nos indicadores e auditorias, identifique oportunidades de melhoria:

- ▶ Ajuste de processos que não estão funcionando
- ▶ Implementação de novas tecnologias de proteção

- ▶ Reforço de treinamentos em áreas problemáticas
- ▶ Atualização de políticas conforme evolução da Instituição
- ▶ Incorporação de melhores práticas do mercado

Ciclo PDCA

Utilize o ciclo Plan-Do-Check-Act (Planejar-Executar-Verificar-Agir) como metodologia para melhoria contínua. A adequação à LGPD é uma jornada, não um destino.

Parabéns!

Ao chegar nesta fase, a Instituição terá um programa robusto de governança de dados. Mantenha o compromisso com a proteção de dados e a conformidade contínua — PGP é programa, não projeto.

• **Como proceder**

A Fase 7 é a que separa órgãos públicos QUE TÊM um PGP dos que TÊM UM PDF chamado PGP guardado em pasta. O programa só EXISTE enquanto está em movimento. Algumas orientações pra esta fase, especialmente conectadas com a Missão 5 do curso (Incidente Surpresa):

• **1. Incidentes vão acontecer — a pergunta é se você está pronto**

Toda Instituição vai ter incidente. Pendrive perdido. Email enviado pra lista errada. Servidor demitido que levou backup. Não é POSSÍVEL prevenir 100%. A diferença entre o órgão que vira manchete e o que resolve nas próximas 72h não é a ausência de incidente — é o PREPARO. Quem tem PRI testado, equipe ETIR definida, matriz RACI clara, descobre o incidente em 1h e comunica em 24h. Quem não tem, descobre pela imprensa.

Res. CD/ANPD nº 15/2024 — o prazo de pesadelo

A ANPD orienta comunicação "em prazo razoável", interpretada como 3 dias úteis pra incidentes de alta severidade. Sem PRI testado, é praticamente impossível cumprir.

• **2. Severidade objetiva (não a 'gut feeling' do DPO)**

A Res. 15/2024 define uma régua objetiva pra severidade: BAIXA (sem acesso indevido), MÉDIA (1 agravante), ALTA (2 agravantes), CRÍTICA (3+ agravantes). Agravantes incluem: dados sensíveis, dados de crianças/idosos, alto volume,

dados financeiros. O app aplica essa régua automaticamente. Não chuta severidade — calcula.

- **3. Métricas que matam: 5 KPIs essenciais**

Não invente 30 KPIs que ninguém vai medir. Comece com 5 que importam: (1) tempo médio de resposta DSR vs. prazo legal de 15 dias úteis, (2) número de incidentes/trimestre vs. trimestre anterior, (3) % de servidores treinados em 12 meses, (4) índice de conformidade em auditoria interna anual, (5) RIPDs realizados vs. processos críticos que exigem. Se esses 5 estão saudáveis, o resto vem.

- **4. Acompanhamento legislativo é parte do método**

A ANPD publica guias, resoluções e orientações regularmente — desde 2022 já saíram 15+ instrumentos relevantes. Ignorar isso é estar a 1 ano de atraso por padrão. Crie um RITUAL: 1 hora por mês, o DPO + 1 servidor (Procuradoria?) abrem o site da ANPD, leem o que foi publicado, decidem o que precisa virar ação no Plano. Custo: 12h/ano. Economia: não virar manchete por descumprimento de regra que existe há 6 meses.

- **5. Auditoria interna anual é não-negociável**

Programa sem auditoria interna anual vira ficção em 12 meses. Não precisa ser auditoria externa cara — pode ser uma colega da Controladoria ou Auditoria Interna, com checklist baseado no GAP. Roda em 2-3 dias. Resultado: relatório com não-conformidades + plano de correção. Esse documento É a evidência viva do princípio de accountability (Art. 6º X LGPD).

- **6. PGP é programa contínuo, não projeto pontual**

A frase que define a Fase 7: "PROGRAMA, não projeto". Projeto tem fim. Programa não. A cada ciclo (anual), você revisa o que mudou, refaz o que precisa, melhora o que descobriu. É como manter um prédio — nunca acaba, sempre há manutenção, mas se você parar de fazer manutenção, o prédio desaba aos poucos. Não dramatize — apenas mantenha o ritmo.



Modelos de referência

- **Registro de incidente — exemplo**

Estrutura típica de registro de incidente conforme Art. 48 LGPD + Resolução CD/ANPD nº 15/2024:

Título do incidente

Acesso indevido a planilha de cadastro de servidores

Severidade

ALTA

Status (encerrado)

Encerrado

Comunicado à ANPD

Sim — em até 3 dias úteis

Comunicado aos titulares

Sim — em até 7 dias úteis (severidade ALTA/CRÍTICA)

Descrição

Servidor com acesso amplo ao sistema acessou planilha de cadastro contendo dados de 250 colegas (CPF, conta bancária, dados de dependentes) e fez cópia local sem autorização institucional. Detectado por auditoria de logs ~5 dias depois.

Medidas de mitigação aplicadas

- Revogação imediata do acesso do servidor envolvido
- Apuração disciplinar instaurada
- Notificação individual aos titulares afetados em até 7 dias
- Revisão dos perfis de acesso no sistema

- **Plano de Resposta a Incidentes (PRI) — estrutura recomendada**

Documento institucional que define a equipe responsável (ETIR) e a matriz de responsabilidades por etapa NIST (Detectar / Conter / Erradicar / Recuperar / Lições aprendidas). Tem que estar pronto ANTES do incidente acontecer.

Equipe de Tratamento de Incidentes — composição típica:

- ▶ DPO — função: Primário. Contato 24h obrigatório (preferencialmente celular institucional)

- ▶ TI — função: Primário. Contato 24h obrigatório (preferencialmente celular institucional)
- ▶ JURIDICO — função: Primário. Contato 24h obrigatório (preferencialmente celular institucional)
- ▶ COMUNICACAO — função: Primário. Contato 24h obrigatório (preferencialmente celular institucional)
- ▶ ALTA_GESTAO — função: Aprovador. Contato 24h obrigatório (preferencialmente celular institucional)

Matriz RACI por etapa NIST — distribuição típica:

Etapa

Papel

Tipo

Detectar

TI

R (responsável)

Detectar

DPO

I (informado)

Conter

TI

R (responsável)

Conter

DPO

A (aprovador)

Erradicar

TI

R (responsável)

Erradicar

JURIDICO

C (consultado)

Recuperar

TI

R (responsável)

Recuperar

DONO_PROCESSO

C (consultado)

Lições aprendidas

DPO

R (responsável)

Lições aprendidas

ALTA_GESTAO

I (informado)



Como aplicar na sua Instituição

- ▶ Realizar simulado de incidente pelo menos 1 vez ao ano — tabletop exercise com cenário plausível.
- ▶ Atualizar o PRI a cada mudança significativa de equipe, sistema ou perímetro.
- ▶ Estabelecer fluxo claro pra comunicação à ANPD (formulário pronto, lista de informações obrigatórias, aprovação interna).
- ▶ Manter histórico de incidentes registrados (mesmo os de baixa severidade) — vira insumo pra a revisão anual do PGP.



Modelo — Comunicação de Incidente à ANPD

Modelo de comunicação à Autoridade Nacional de Proteção de Dados (ANPD) em caso de incidente de segurança com dados pessoais, conforme Art. 48 da LGPD e Resolução CD/ANPD nº 15/2024. Prazo: até 3 dias úteis após o conhecimento do incidente.

Campos obrigatórios:

- ▶ Identificação do controlador: nome, CNPJ, endereço, dados do Encarregado
- ▶ Data e horário em que o incidente ocorreu (se conhecido) e em que foi detectado
- ▶ Descrição da natureza dos dados pessoais afetados
- ▶ Categorias e número aproximado de titulares afetados
- ▶ Indicação das medidas técnicas e de segurança utilizadas
- ▶ Riscos relacionados ao incidente
- ▶ Medidas adotadas para mitigar os efeitos
- ▶ Indicação do motivo do atraso, caso a comunicação não tenha sido imediata
- ▶ Identificação do responsável pela comunicação

A comunicação é feita pelo portal da ANPD (gov.br/anpd → Comunicações à Autoridade). Para incidentes de severidade ALTA ou CRÍTICA, comunicar TAMBÉM aos titulares afetados em até 7 dias úteis (modelo de comunicação ao titular vem como anexo).



CAPÍTULOS DE CONSULTA • GLOSSÁRIO

Glossário LGPD essencial

30 termos críticos organizados por ordem alfabética com definição compatível com a Lei. Use como referência rápida durante a leitura desta Cartilha e nas reuniões do Comitê de Privacidade.

Anonimização

Utilização de meios técnicos razoáveis e disponíveis no momento do tratamento, por meio dos quais um dado perde a possibilidade de associação, direta ou indireta, a um indivíduo. DIFERENTE de pseudonimização (que mantém a possibilidade de reidentificação).

Base: Art. 5º XI

ANPD (Autoridade Nacional)

Autoridade Nacional de Proteção de Dados — órgão da Administração Pública federal responsável por zelar pela proteção de dados pessoais, fiscalizar o cumprimento da LGPD, aplicar sanções.

Base: Art. 55-A

Aviso de Privacidade

Documento público (no portal externo da Instituição) que informa ao titular como seus dados são tratados — finalidades, bases legais, retenção, compartilhamentos, canal de exercício de direitos.

Base: Art. 9º

Banco de dados

Conjunto estruturado de dados pessoais, estabelecido em um ou mais locais, em suporte eletrônico ou físico.

Base: Art. 5º IV

Base legal (hipótese de tratamento)

Fundamento jurídico que autoriza o tratamento. Para dados comuns são 10 hipóteses (Art. 7º); para dados sensíveis são 8 hipóteses mais restritivas (Art. 11).

Toda atividade de tratamento precisa de UMA base legal documentada.

Base: Art. 7º · Art. 11

Comitê de Privacidade

Instância multidisciplinar interna do órgão (TI, Jurídico, Comunicação, RH, áreas de negócio) que apoia o Encarregado nas decisões estratégicas do PGP. Recomendado em todos os órgãos médios e grandes.

Base: Boas práticas + Res. 18/2024

Compartilhamento de dados (setor público)

Uso compartilhado de dados pessoais por órgão público com outros órgãos ou pessoas jurídicas. Permitido se houver finalidade específica, execução de políticas públicas e atribuições legais — sempre informado ao titular.

Base: Art. 26

Consentimento

Manifestação LIVRE, INFORMADA e INEQUÍVOCA pela qual o titular concorda com o tratamento de seus dados pessoais para uma finalidade determinada. Caixa pré-marcada NÃO é consentimento válido.

Base: Art. 5º XII · Art. 8º

Controlador

Pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais. No setor público, é o próprio órgão (ex: Prefeitura, Câmara, Tribunal, Autarquia).

Base: Art. 5º VI

Dado anonimizado

Dado relativo a titular que NÃO possa ser identificado, considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião do tratamento. Sai do escopo da LGPD.

Base: Art. 5º III · Art. 12

Dado pessoal

Informação relacionada a pessoa natural identificada ou identificável. Inclui nome, CPF, e-mail, foto, geolocalização, IP — qualquer dado que possa identificar uma

pessoa direta ou indiretamente.

Base: Art. 5º I

Dado pessoal sensível

Dado sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou organização de caráter religioso/filosófico/político, dado de saúde, dado da vida sexual, dado genético ou biométrico, quando vinculado a pessoa natural.

Base: Art. 5º II

Direitos do Titular (DSR)

Conjunto de direitos garantidos ao titular: confirmação de tratamento, acesso, correção, anonimização/bloqueio/eliminação, portabilidade, informação sobre compartilhamento, revogação de consentimento. Atendimento em 15 dias úteis.

Base: Art. 18 · Art. 19 II

Encarregado (DPO)

Pessoa indicada pelo controlador para atuar como canal de comunicação entre o controlador, os titulares e a Autoridade Nacional (ANPD).

Base: Art. 5º VIII · Art. 41

Finalidade

Princípio do tratamento. Os dados só podem ser tratados pra propósitos legítimos, específicos, explícitos e informados ao titular — sem possibilidade de tratamento posterior incompatível.

Base: Art. 6º I

Incidente de segurança

Qualquer evento adverso confirmado, relacionado à violação na segurança de dados pessoais — acesso não autorizado, perda, alteração, eliminação, comunicação ou difusão indevida. Comunicar à ANPD em até 3 dias úteis; aos titulares afetados em até 7 dias úteis.

Base: Art. 48 · Res. CD/ANPD 15/2024

Inventário de Tratamentos

Registro estruturado de TODOS os processos de tratamento de dados pessoais da Instituição — finalidade, base legal, tipos de dados, retenção, compartilhamentos, medidas de segurança por processo.

Base: Art. 37

Necessidade

Princípio do tratamento. Limitação ao mínimo necessário pra atingir a finalidade — dados pertinentes, proporcionais e não excessivos.

Base: Art. 6º III

Operador

Pessoa natural ou jurídica que realiza o tratamento de dados pessoais em nome do controlador. Ex: empresa contratada pra hospedar o sistema de prontuários, processadora da folha de pagamento.

Base: Art. 5º VII

PRI (Plano de Resposta a Incidentes)

Documento institucional que define equipe responsável, fluxo de decisão, matriz RACI por etapa NIST (Detectar, Conter, Erradicar, Recuperar, Lições) e modelos de comunicação pra resposta a incidentes de segurança com dados pessoais.

Base: Art. 46 + Art. 48

Privacy by Design / Default

Princípio segundo o qual a proteção de dados deve ser considerada DESDE A CONCEPÇÃO de qualquer novo sistema, processo ou serviço — e configurada por padrão. Princípio refletido no Art. 46.

Base: Art. 46

Programa de Governança em Privacidade (PGP)

Conjunto integrado de instrumentos institucionais (Inventário, Riscos, GAP, Plano, RIPDs, Operadores, DSR, Aviso, PRI) que organizam a conformidade da Instituição à LGPD. Aprovado por ato formal do dirigente máximo.

Base: Art. 50

RIPD (Relatório de Impacto)

Documento que descreve o tratamento de dados pessoais que pode gerar riscos às liberdades civis e direitos fundamentais. Obrigatório pra tratamentos de alto risco (dados sensíveis, larga escala, decisões automatizadas, vigilância sistemática).

Base: Art. 5º XVII · Art. 38

Sanção administrativa

Penalidades aplicadas pela ANPD em caso de descumprimento: advertência, publicização da infração, multa de até 2% do faturamento (limitada a R\$ 50 milhões por infração), bloqueio ou eliminação dos dados, suspensão parcial ou total das atividades.

Base: Art. 52 · Res. CD/ANPD 4/2023

Titular

Pessoa natural a quem se referem os dados pessoais objeto de tratamento.

Base: Art. 5º V

Transferência internacional

Transferência de dados pessoais para país estrangeiro. Permitida apenas em hipóteses específicas: adequação reconhecida pela ANPD, garantias contratuais, normas corporativas globais, consentimento específico, cumprimento de obrigação legal, execução de política pública, defesa em processo, proteção da vida do titular.

Base: Art. 33 · Res. CD/ANPD 20/2024

Transparência

Princípio do tratamento. Garantia ao titular de informações claras, precisas e facilmente acessíveis sobre o tratamento e seus respectivos agentes.

Base: Art. 6º VI

Tratamento

Toda operação realizada com dados pessoais: coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, modificação, comunicação, transferência, difusão ou extração.

Base: Art. 5º X

Tratamento por órgão público

Tratamento realizado por pessoa jurídica de direito público em decorrência de competência legal ou execução de políticas públicas. Tem regime parcialmente próprio — Capítulo IV da LGPD (Arts. 23-32).

Base: Cap. IV (Art. 23-32)

Vulneráveis (dados de)

Crianças, adolescentes, idosos e demais grupos em situação de vulnerabilidade. Tratamento exige cuidados específicos: dados de crianças/adolescentes só com consentimento de um dos pais ou responsável legal; melhor interesse da criança como princípio.

Base: Art. 14



Base legal — guia decisivo para o Setor Público

Toda atividade de tratamento de dados precisa de uma base legal documentada. A LGPD oferece 10 hipóteses para dados comuns (Art. 7º) e 8 hipóteses mais restritivas para dados sensíveis (Art. 11). No setor público, NEM TODAS são utilizáveis ou recomendadas — algumas são típicas do setor privado.

Use o fluxograma abaixo pra decidir a base legal apropriada pra cada processo no Inventário. Quando há múltiplas opções aplicáveis, escolher a mais específica e estável (cumprimento de obrigação legal > execução de política pública > legítimo interesse).



Fluxograma de decisão

1. O tratamento envolve dados pessoais SENSÍVEIS (saúde, opinião política, religião, biometria, etc.)?

→ SIM: Vai pro Art. 11. Base mais comum no setor público: Art. 11 II 'a' (cumprimento de obrigação legal pelo controlador) OU Art. 11 II 'b' (tratamento compartilhado de dados necessários à execução de políticas públicas previstas em leis e regulamentos) OU Art. 11 II 'f' (tutela da saúde, exclusivamente em procedimento realizado por profissionais de saúde, serviços de saúde ou autoridade sanitária).

→ NÃO: Vai pro Art. 7º (próxima pergunta).

2. O tratamento decorre de OBRIGAÇÃO LEGAL ou REGULAMENTAR específica (ex: registrar contribuição previdenciária, manter livro fiscal, processar folha de pagamento)?

→ SIM: Base legal: Art. 7º II (cumprimento de obrigação legal ou regulatória). É a base MAIS estável — citar a lei específica que obriga (ex: Lei nº 8.112/90 art. X, Lei nº 8.666/93 art. Y, etc.).

→ NÃO: Próxima pergunta.

3. O tratamento é necessário pra EXECUTAR UMA POLÍTICA PÚBLICA prevista em lei, regulamento ou contrato (ex: atender em UBS, oferecer programa social, fiscalizar atividade econômica)?

→ SIM: Base legal: Art. 7º III (tratamento e uso compartilhado de dados necessários à execução de políticas públicas previstas em leis e regulamentos ou respaldadas em contratos, convênios ou instrumentos congêneres). É a base TÍPICA do setor público pra serviços ao cidadão.

→ NÃO: Próxima pergunta.

4. O tratamento é necessário pra EXECUÇÃO DE CONTRATO ou DE PROCEDIMENTOS PRELIMINARES a contrato em que o titular seja parte (ex: licitação, contratação direta)?

→ SIM: Base legal: Art. 7º V (execução de contrato ou procedimentos preliminares relacionados).

→ NÃO: Próxima pergunta.

5. É indispensável pra PROTEGER A VIDA OU INCOLUMIDADE FÍSICA do titular ou de terceiro (ex: atendimento de urgência, comunicação a familiares em risco)?

→ SIM: Base legal: Art. 7º IV (proteção da vida ou incolumidade física). Excepcional — usar quando houver risco imediato.

→ NÃO: Próxima pergunta.

6. É pra EXERCÍCIO REGULAR DE DIREITOS em processo judicial, administrativo ou arbitral (ex: prova em ação judicial)?

→ SIM: Base legal: Art. 7º VI (exercício regular de direitos em processo judicial, administrativo ou arbitral).

→ NÃO: Próxima pergunta.

7. É necessário pra atender LEGÍTIMOS INTERESSES do controlador ou de terceiro?

→ SIM: Base legal: Art. 7º IX (legítimo interesse). CUIDADO: no setor público é uso EXCEPCIONAL. Exige teste de balanceamento documentado (LIA — Legitimate Interest Assessment). Não substitui base mais específica quando esta existir.

→ NÃO: Próxima pergunta.

8. O tratamento é FACULTATIVO do ponto de vista do cidadão (ele pode escolher se quer ou não, sem prejuízo do serviço público principal)?

→ SIM: Base legal: Art. 7º I (consentimento). É a base MAIS FRÁGIL — pode ser revogada a qualquer momento. Usar apenas em tratamentos genuinamente facultativos (newsletter voluntária, autorização de imagem em material promocional).

→ NÃO: Reavaliar — provavelmente cabe Art. 7º II ou III. Não há tratamento sem base legal.



Erros comuns de classificação

- ▶ ❌ Usar consentimento pra atendimento OBRIGATÓRIO de cidadão (ex: ficha cadastral pra ser atendido na UBS). O cidadão não pode escolher — então não é consentimento. Base correta: Art. 7º III + Art. 11 II 'f' (saúde).
- ▶ ❌ Usar interesse legítimo no setor público sem teste de balanceamento. Interesse legítimo exige documentação demonstrando que a finalidade legítima do controlador supera os direitos do titular naquele contexto.
- ▶ ❌ Pular Art. 11 quando há dados sensíveis. Mesmo que haja base no Art. 7º, dados sensíveis exigem base ADICIONAL do Art. 11.
- ▶ ❌ Generalizar uma só base pra todo o órgão. Cada processo do Inventário deve ter base ESPECÍFICA — não basta dizer "obrigação legal" sem citar a lei.

Regra de ouro

REGRA DE OURO: começar sempre pelo Art. 7º II (obrigação legal específica) ou Art. 7º III (política pública). Essas duas bases cobrem 80-90% dos tratamentos típicos do setor público. Consentimento e legítimo interesse só pra casos genuinamente facultativos ou excepcionais.



Armadilhas comuns no setor público

Determinadas práticas de tratamento de dados pessoais aparecem com frequência nos órgãos públicos brasileiros — algumas por inércia ("sempre foi assim"), outras por interpretação incorreta da Lei, outras por excesso de zelo na direção errada. Este capítulo reúne 10 armadilhas observadas em múltiplas Instituições, com explicação do erro, base legal aplicável e como evitar.

Use este capítulo durante a revisão do Inventário e do Aviso de Privacidade. Para cada processo / cada seção do Aviso, perguntar: "caímos em alguma dessas?" — exercício rápido que pega muitos problemas que escapam ao olhar técnico.

As 4 primeiras armadilhas envolvem CONFIGURAÇÕES DE PROCESSOS (saúde, RH, comunicação, ouvidoria). As 6 últimas envolvem CONFIGURAÇÕES DO AVISO DE PRIVACIDADE — texto que vai ao cidadão.



Armadilhas em processos (4)

- **Prefeitura — Posto de Saúde — empresa de marketing parceira**

Situação típica:

"O posto também envia 'relatórios mensais com lista nominal e telefone dos pacientes hipertensos e diabéticos' pra uma empresa de marketing parceira do município, que vende 'serviço de campanhas de vacinação personalizadas via WhatsApp'. A direção do posto acha que isso é OK porque 'é pra ajudar o paciente'."

Por que é armadilha:

Compartilhar lista nominal + dados de saúde com fim comercial NÃO é finalidade de saúde pública. Falta base legal específica do Art. 11 (dados sensíveis) e contraria o princípio da finalidade (Art. 6º I). Mesmo que a empresa seja 'parceira', tratamento secundário com dados sensíveis exige consentimento específico do titular ou hipótese explícita do Art. 11 — não basta a finalidade declarada do processo original.

Base legal aplicável: Art. 6º I (finalidade) · Art. 11 (dados sensíveis) · Art. 39 (operador)

Como evitar / Como discutir: Pergunte 'qual base legal autoriza enviar dado sensível pra empresa comercial?'. Premie grupo que cita Art. 11 e diferencia 'parceira pra fim público' de 'parceira pra fim comercial'. Note também: falta DPA (Data Processing Agreement) com a empresa.

- **Prefeitura — Estagiários — newsletter com checkbox pré-marcado**

Situação típica:

"O e-mail automático que vai pro candidato após a inscrição também envia 'newsletter da Prefeitura' sobre eventos culturais — a caixa de check 'aceito receber comunicados' vem marcada por padrão no formulário."

Por que é armadilha:

Consentimento marcado por padrão (opt-out) NÃO é consentimento válido segundo a LGPD. O Art. 5º XII exige manifestação 'livre, informada, inequívoca e por meio de declaração ou ato afirmativo claro'. O padrão deve ser opt-in: caixa desmarcada por padrão, o titular marca se quiser. Adicionalmente, a finalidade 'eventos culturais' é distinta da finalidade do processo (seleção de estagiários) — exige consentimento separado.

Base legal aplicável: Art. 5º XII · Art. 8º (consentimento) · Art. 6º I (finalidade)

Como evitar / Como discutir: Pergunte: 'caixa pré-marcada é consentimento válido?'. Quem responder 'não, exige ato afirmativo' acerta. Cite Resolução CD/ANPD nº 4/2024 (sanções) — multas por consentimento inválido vão de 0.5 a 2% do faturamento.

- **Câmara — Tribuna Livre — reels no Instagram sem aviso**

Situação típica:

"Após a sessão, o setor de Comunicação publica reels no Instagram da Câmara com 'trechos das melhores falas' — incluindo nome do cidadão na legenda. O formulário de inscrição avisa sobre a transmissão ao vivo no YouTube, mas não menciona o Instagram."

Por que é armadilha:

A base legal (execução de políticas públicas + interesse público) cobre a transmissão ao vivo no YouTube — finalidade declarada e prevista no edital de inscrição. Reels editados no Instagram extrapolam essa finalidade: viram comunicação institucional/marketing, com público diferente, alcance diferente, expectativa diferente do cidadão. É uso secundário sem informação prévia ao titular (Art. 6º I, IV; Art. 9º).

Base legal aplicável: Art. 6º I (finalidade) · Art. 6º IV (livre acesso) · Art. 9º (informação)

Como evitar / Como discutir: Pergunte 'o cidadão sabia que ia parar em reels de Instagram quando se inscreveu?'. Aprofunde: 'transmissão pública' tem alcance institucional; 'reels' tem alcance de marketing — não são equivalentes. O formulário precisaria avisar AMBOS os canais.

- **Câmara — Ouvidoria — newsletter trimestral pra quem reclamou**

Situação típica:

"A Ouvidoria envia trimestralmente uma 'newsletter com os principais temas das manifestações' pra TODOS os cidadãos que entraram em contato no ano. A justificativa interna é 'transparência ativa'. A base legal alegada é 'interesse legítimo da Câmara em informar a sociedade'."

Por que é armadilha:

Interesse legítimo (Art. 10) exige teste de balanceamento: a finalidade legítima do controlador supera os direitos do titular naquele contexto? Aqui NÃO passa — o titular procurou a Ouvidoria pra resolver UMA questão específica, não pra receber newsletter. A expectativa razoável dele NÃO inclui ser mailing recorrente. Mistura de finalidades sem informação prévia (Art. 6º I, VI). Adicionalmente, 'transparência ativa' é princípio da LAI (Lei nº 12.527/2011), que se cumpre publicando no portal — não no e-mail individual de quem reclamou.

Base legal aplicável: Art. 6º I, VI · Art. 10 (interesse legítimo) · Lei nº 12.527/2011 (LAI)

Como evitar / Como discutir: Pergunte 'o cidadão esperava receber newsletter quando reclamou de buraco na rua?'. Quem responde 'não, expectativa não bate' acerta. Aprofunde: legítimo interesse precisa de finalidade compatível + expectativa razoável + balanceamento documentado. Sem isso, é só marketing disfarçado.



Armadilhas no Aviso de Privacidade (6)

- **Base legal incorreta — usa 'consentimento' pra atividade pública**

Onde aparece: Seção 4 — Base legal

Por que é armadilha:

Serviço público (Posto de Saúde, Tribuna, Ouvidoria, Estagiários) NÃO usa consentimento como base legal. O correto é 'execução de políticas públicas' (art. 7º, III) ou 'obrigação legal' (art. 7º, II). Consentimento exige possibilidade real de recusa — o cidadão que precisa do SUS não pode 'recusar' o cadastro e ainda ser atendido.

Base legal: Art. 7º, II, III · Art. 11, II 'a'

Como evitar: Pergunte 'qual seria a base correta?' — premie grupo que cita art. 7º III ou art. 11 II 'a'. Quem passou batido, explique no debrief.

- **Dados sensíveis silenciados**

Onde aparece: Seção 3 — Quais dados tratamos

Por que é armadilha:

Quando o processo tem `sc-camel-dados-sensíveis=true` no Inventário (ex: prontuário do Posto, denúncias da Ouvidoria), o Aviso deveria informar isso AO TITULAR. O auto-preencher omitiu a marca '(inclui dados pessoais sensíveis)' — viola transparência (art. 6º, VI) e dever de informação sobre sensíveis (art. 11).

Base legal: Art. 5º, II · Art. 6º, VI · Art. 11

Como evitar: Confira no Inventário quais processos têm `sc-camel-dados-sensíveis=true`. Procure no Aviso a menção 'sensíveis' nessas seções. Se está omitido, é erro plantado.

- **Retenção vaga ('pelo tempo necessário')**

Onde aparece: Seção 5 — Por quanto tempo guardamos

Por que é armadilha:

LGPD exige prazo CLARO e ESPECÍFICO de retenção (art. 16). Texto genérico como 'pelo tempo necessário às finalidades' não cumpre transparência (art. 6º, VI) nem

necessidade (art. 6º, III). Mesmo com prazos específicos no Inventário, o auto-preencher substituiu por uma frase genérica.

Base legal: Art. 6º, III, VI · Art. 16

Como evitar: Compare o que está no Inventário (retenção por processo) com o Aviso. Se sumiram os prazos específicos, é erro plantado.

- **Linguagem juridiquês ('outrossim', 'consoante') em vez de clara**

Onde aparece: Seção 6 — Como protegemos seus dados

Por que é armadilha:

Princípio do livre acesso e da transparência (art. 6º, VI) exige linguagem CLARA, ADEQUADA E OSTENSIVA pro titular comum. 'Outrossim', 'consoante o disposto', 'mutatis mutandis' são juridiquês — afastam o cidadão da informação. Aviso bom é em português simples.

Base legal: Art. 6º, VI · Art. 9º (informação clara)

Como evitar: Procure palavras como 'outrossim', 'consoante', 'mister', 'destarte'.

Pergunte: 'sua mãe entenderia esta seção?'

- **Transferência internacional negada sem checar operadores**

Onde aparece: Seção 8 — Transferência internacional

Por que é armadilha:

Diz 'não realizamos transferência internacional' sem verificar os operadores cadastrados. Mas o OuviTech (sistema de Ouvidoria SaaS) pode ter servidores fora do BR — cloud global. Buffet pode usar Google Forms (servidores nos EUA). Negar sem checar é informar errado o titular (art. 33).

Base legal: Art. 33 · Art. 9º (transparência)

Como evitar: Pergunte: 'algum operador usa cloud global ou SaaS? Onde estão os servidores?' Quem investigou tem ponto. Cite a Resolução CD/ANPD nº 20/2024.

- **Canal DSR genérico em vez do canal real estruturado**

Onde aparece: Seção 11 — Como exercer seus direitos

Por que é armadilha:

Usa contato genérico ('[\[email protected\]](#)') em vez do canal funcional que o grupo estruturou na M4a (Direitos do Titular). O canal precisa estar VIVO, acessível e divulgado (art. 18 §6º). Prometer um canal que não existe é estelionato regulatório.

Base legal: Art. 18 · Art. 18 §6º · Art. 19, II

Como evitar: Compare: o e-mail do Aviso é o mesmo do Encarregado cadastrado em Fase 1? Existe canal alternativo (formulário web)? Quem alinhou tem ponto.

Lembrete

Nenhuma destas armadilhas é "erro de gestor mal-intencionado" — todas são erros humanos comuns que aparecem porque a LGPD ainda é Lei nova, com pouca jurisprudência consolidada, e o setor público tem cultura própria muito enraizada. Por isso a revisão estruturada importa: o erro escapa do olhar técnico individual, mas não escapa do checklist coletivo.



CAPÍTULOS DE CONSULTA • ADAPTAÇÃO

Adaptação por porte do órgão

A LGPD aplica-se igualmente a órgãos pequenos e grandes — mas o COMO implementar tem que se adaptar à realidade institucional. Tentar replicar em uma Prefeitura de 50 servidores o modelo de uma Câmara Federal é receita pra falha (e o contrário também).

Esta seção orienta as decisões operacionais por porte. Lembrar: porte NÃO determina o que precisa cumprir, apenas COMO cumprir.



Pequeno (até 30 servidores)

Câmaras municipais de cidades pequenas, autarquias compactas, conselhos profissionais regionais. Equipe enxuta, sem TI especializada, orçamento limitado.

- **Orientações operacionais**

Encarregado: pode ser servidor com acúmulo de função (jurídico + DPO, ou administração + DPO). Designar formalmente mesmo assim — a função existe na Lei.

Comitê de Privacidade: 3 membros (DPO + um da área técnica + um da área-fim). Reuniões trimestrais.

Inventário: focar em 5-10 processos críticos. Cobertura total leva tempo — priorizar por risco.

GAP: usar pacote enxuto (10-15 controles essenciais), não os 30/119 completos.

RIPDs: só pra processos genuinamente sensíveis (saúde, dados de crianças). Não exagerar.

Aviso de Privacidade: 1 modelo institucional simples, atualizado a cada mudança real.

PRI: equipe = a mesma do Comitê de Privacidade. Sem CSIRT especializado.

Treinamento: capacitação anual coletiva (2-3h) — não consultoria cara.

Orçamento aproximado:

Pode caber em rubrica de capacitação existente. Investimentos extras: ~R\$ 5-15 mil/ano (treinamento, eventual consultoria pontual).



Médio (30 a 200 servidores)

Prefeituras de cidades médias, Câmaras municipais maiores, autarquias regionais, tribunais regionais menores. TI estruturada, jurídico próprio.

- **Orientações operacionais**

Encarregado: ideal dedicar 30-50% do tempo de um servidor pra função (não 100%, mas com horas reservadas). Pode ter Substituto formal.

Comitê de Privacidade: 5-7 membros (DPO + TI + Jurídico + Comunicação + 1-2 áreas-fim). Reuniões mensais.

Inventário: 20-50 processos esperados. Cobrir Saúde, Educação, Tributário, RH, Assistência Social, Tributação.

GAP: pacote intermediário (30-50 controles). Pode estender pra controles específicos do setor.

RIPDs: ~5-10 elaborados nos primeiros 12 meses (processos críticos).

Aviso de Privacidade: 1 institucional + Avisos específicos por serviço de alto impacto.

PRI: equipe formalizada (5-7 papéis) com matriz RACI clara. Simulado anual.

Treinamento: trilha de capacitação anual + onboarding obrigatório + pílulas mensais (e-mail/intranet).

Orçamento aproximado:

Rubrica específica recomendada. Investimentos: ~R\$ 30-80 mil/ano (treinamento + ferramentas + eventual consultoria).



Grande (200+ servidores)

Prefeituras de cidades grandes/capitais, Câmaras Estaduais e Federal, Tribunais de Justiça/Contas, Autarquias federais, agências reguladoras. Estrutura tecnológica robusta, jurídico especializado.

- **Orientações operacionais**

Encarregado: função DEDICADA (100% tempo) + Substituto + equipe de apoio (2-5 servidores). Pode ser servidor de carreira específica.

Comitê de Privacidade: 10-15 membros com representação de TODAS as áreas-chave. Reuniões mensais + grupos de trabalho temáticos.

Inventário: 100+ processos. Ferramenta dedicada (planilha não basta). Revisão contínua.

GAP: pacote completo (119+ controles). Avaliação multi-setor com pareceres técnicos formais.

RIPDs: programa estruturado — todos os processos de alto risco com RIPD aprovado.

Aviso de Privacidade: institucional + Avisos por serviço (10-30 avisos específicos).

PRI: CSIRT formalizado, simulados semestrais, integração com SIEM, contrato com forense externo.

Treinamento: capacitação contínua, plataforma EAD própria, certificação interna, indicadores de cobertura.

Orçamento aproximado:

Rubrica específica obrigatória. Investimentos: R\$ 150 mil/ano +, com possível contratação de ferramentas SaaS (Privacy Management Platform), consultoria especializada, infraestrutura.

Atenção

Estas orientações são parâmetros — adaptar à realidade específica. Característica que pode SOBRESCREVER o porte: tratamento de dados sensíveis em larga escala (ex: Secretaria Estadual de Saúde tem porte 'grande' independentemente do nº de servidores administrativos).



Calendário recomendado de revisões

Conformidade LGPD não é projeto com fim — é processo contínuo. Esta tabela orienta a periodicidade típica de revisão de cada instrumento do PGP. Adapte conforme o porte e os eventos disparadores específicos da sua Instituição.

- **Inventário de Tratamentos**

Periodicidade

Anual + atualização contínua

Por que

Processos novos, sistemas trocados, áreas reorganizadas — sem atualização contínua, o Inventário envelhece rápido.

Além disso

Cada novo sistema/processo deve entrar no Inventário ANTES do início do tratamento (privacy by design).

- **Análise de Riscos**

Periodicidade

Anual + após incidente significativo

Por que

Riscos mudam com tecnologia, terceiros e contexto. Após incidente, reavaliar a probabilidade dos riscos correlatos.

Além disso

Mudanças significativas nos processos do Inventário disparam reavaliação de riscos associados.

- **GAP Analysis**

Periodicidade

Anual

Por que

Conformidade é alvo móvel — novas resoluções ANPD, decisões judiciais, jurisprudência. Repetir o GAP mostra evolução.

Além disso

Cada 'NÃO ADERENTE' deve gerar ação no Plano com responsável e prazo. Sem ação, lacuna persiste indefinidamente.

- **Plano de Ação**

Periodicidade

Mensal (acompanhamento) + revisão trimestral

Por que

Plano sem acompanhamento vira papel. Reuniões mensais do Comitê pra acompanhar status; trimestrais pra repriorizar.

Além disso

Ações concluídas devem ser arquivadas, não excluídas — histórico institucional.

- **RIPDs**

Periodicidade

Anual + após mudança significativa no processo

Por que

Novo sistema, novo operador, alteração legislativa — exigem reavaliação do impacto.

Além disso

RIPD desatualizado é problema em fiscalização: ANPD pergunta data da última revisão.

- **Cláusulas LGPD nos contratos com operadores**

Periodicidade

Por contrato — verificação anual + na renovação

Por que

Contratos antigos (pré-2020) frequentemente não têm cláusulas LGPD. Promover aditamento progressivamente.

Além disso

Novos contratos devem incluir cláusulas LGPD desde a redação.

- **Canal DSR (Direitos do Titular)**

Periodicidade

Verificação mensal de funcionamento + revisão anual do procedimento

Por que

Canal precisa estar VIVO — testar o e-mail/formulário todo mês. Sem funcionamento, ANPD considera descumprimento direto do Art. 18.

Além disso

Indicador trimestral: % de solicitações respondidas em até 15 dias úteis (Art. 19 II).

- **Aviso de Privacidade público**

Periodicidade

A cada mudança no Inventário + revisão semestral

Por que

Aviso desatualizado em relação ao Inventário é informação incorreta ao titular (Art. 6º VI).

Além disso

Inclui data da última atualização visível na página pública.

- **Plano de Resposta a Incidentes (PRI)**

Periodicidade

Anual + após incidente real

Por que

Equipe muda (servidores trocam de função), tecnologia muda, fluxo muda. PRI desatualizado falha na hora certa.

Além disso

Recomendado: simulado anual (tabletop exercise) com cenário plausível. Sem simulado, plano é só papel.

- **Política do PGP (documento mater)**

Periodicidade

Anual

Por que

Aprovação anual pelo dirigente máximo cria ritual institucional. Política sem revisão é política esquecida.

Além disso

Anexar relatório executivo (1-2 páginas) com o status de cada instrumento.

- **Capacitação da equipe**

Periodicidade

Anual + onboarding obrigatório

Por que

Capacitação não é evento único. Equipe muda. Lei muda. Necessário pulsing periódico.

Além disso

Onboarding obrigatório PRA NOVOS SERVIDORES antes de tratar dados pessoais (Art. 50 § 2º I 'c').



CAPÍTULOS DE CONSULTA • CHECKLIST

Checklist final do PGP

25 perguntas de auto-avaliação organizadas pelas 8 etapas do PGP. Marque  se cumprido,  se parcial e  se pendente. Score auto-avaliativo: 23-25  = PGP maduro; 18-22 = consolidação; 12-17 = em construção; abaixo de 12 = início. Repetir a cada 6 meses pra acompanhar evolução.



Fase Preliminar — Sensibilização

- ☐ A Alta Gestão (dirigente máximo) tem ciência formal do PGP e demonstra apoio institucional?
- ☐ A equipe envolvida no tratamento de dados recebeu capacitação nos últimos 12 meses?
- ☐ Há documento que registra o ponto de partida da maturidade institucional (auto-diagnóstico, termômetro)?



Fase 1 — Governança

- ☐ O Encarregado pelo Tratamento de Dados Pessoais (DPO) foi designado por ato formal e publicado no diário oficial?
- ☐ Os contatos do Encarregado estão divulgados no portal institucional (Art. 41 §1º)?
- ☐ Existe Encarregado Substituto designado pra continuidade em férias/afastamentos?
- ☐ O Comitê de Privacidade foi instituído por ato formal com representantes das áreas-chave?



Fase 2 — Diagnóstico Inicial

- ☐ Foi feito levantamento preliminar dos setores que tratam dados pessoais no órgão?
 - ☐ Foi aplicada Matriz de Priorização (Res. ANPD nº 2/2022) aos processos identificados?
-



Fase 3 — Mapeamento e Riscos

- ☐ Existe Inventário de Tratamentos atualizado nos últimos 12 meses?
 - ☐ Cada processo do Inventário tem base legal documentada e específica?
 - ☐ Foi realizada Análise de Riscos com matriz Probabilidade × Impacto pros processos críticos?
-



Fase 4 — GAP Analysis

- ☐ Foi feita análise de conformidade (GAP) com pelo menos 10 controles essenciais?
 - ☐ Cada controle NÃO ADERENTE virou ação no Plano com responsável e prazo?
-



Fase 5 — Plano de Ação

- ☐ Existe Plano de Ação consolidado com responsável e prazo por ação?
 - ☐ Há acompanhamento periódico do Plano (mensal ou trimestral)?
-



Fase 6 — Execução

- ☐ Existem RIPDs elaborados pros processos de alto risco (dados sensíveis, larga escala)?

- ☐ Os contratos com operadores (terceiros que tratam dados) contêm cláusulas LGPD (Art. 39)?
 - ☐ Existe canal pra exercício de Direitos do Titular (DSR) divulgado e funcional?
 - ☐ Há monitoramento do prazo de 15 dias úteis pra resposta a solicitações DSR (Art. 19 II)?
 - ☐ O Aviso de Privacidade está publicado no portal externo, acessível ao cidadão (Art. 9º)?
 - ☐ Existe Política de Retenção e descarte com prazos por categoria de dado (Art. 16)?
-



Fase 7 — Monitoramento e Resposta

- ☐ Existe Plano de Resposta a Incidentes (PRI) formalizado, com equipe definida e matriz RACI?
- ☐ O PRI foi testado nos últimos 12 meses (simulado)?



Perguntas frequentes (FAQ)

Compilação de perguntas que aparecem com frequência em treinamentos, atendimentos do canal DSR e reuniões do Comitê de Privacidade. As respostas têm caráter orientativo — não substituem parecer jurídico institucional em casos de dúvida significativa.

- **1. Meu órgão é pequeno (menos de 50 servidores). Preciso mesmo de Encarregado?**

SIM. A LGPD não dispensa o Encarregado em função do porte. O que muda é COMO designar: em órgão pequeno, pode ser servidor com acúmulo de função (jurídico + DPO, por exemplo), mas é obrigatório formalizar por ato. A Resolução CD/ANPD nº 18/2024 detalha os critérios — perfil técnico-jurídico compatível, autonomia funcional, ausência de conflito de interesse.

- **2. O Encarregado pode ser servidor temporário ou comissionado?**

Pode, mas com ressalvas. A Resolução CD/ANPD nº 18/2024 não veda servidor temporário/comissionado, MAS aponta que o cargo deve garantir AUTONOMIA FUNCIONAL — a função exige proteção contra retaliação por suas decisões técnicas (Art. 41 §3º). Servidor demissível ad nutum sem garantias específicas tem autonomia comprometida, na prática. Recomendação: preferir servidor de carreira; se for comissionado/temporário, garantir cláusula contratual de estabilidade na função pelo prazo do mandato.

- **3. Posso usar legítimo interesse (Art. 7º IX) no setor público?**

PODE, mas é base EXCEPCIONAL no setor público. A regra é usar bases mais específicas: Art. 7º II (obrigação legal) ou Art. 7º III (execução de políticas públicas). Quando usar legítimo interesse, é OBRIGATÓRIO documentar o teste de balanceamento (LIA): a finalidade legítima do controlador supera os direitos do titular naquele contexto específico? Sem essa documentação, a ANPD pode considerar tratamento sem base legal.

- **4. Por quanto tempo guardo o dado de cidadão atendido?**

DEPENDE da categoria do dado e da legislação aplicável. Parâmetros típicos: dados gerais de atendimento = 5 anos (prazo prescricional padrão); dados de saúde (prontuários) = 20 anos da última consulta (CFM Resolução 1.821/2007); dados fiscais/tributários = 5 anos (legislação tributária); dados previdenciários = até 75 anos. Após o prazo: eliminar, anonimizar ou justificar retenção em hipótese específica (Art. 16). Política de Retenção institucional documenta os prazos por categoria.

- **5. Tenho que pedir consentimento pra tratar dado de servidor?**

NÃO. Tratamento de dados de servidor (folha, ponto, prontuário funcional, etc.) decorre de OBRIGAÇÃO LEGAL (Art. 7º II — Lei nº 8.112/90 ou estatuto local + legislação previdenciária/tributária/fiscal). Consentimento é base inadequada porque o servidor não pode RECUSAR sem prejuízo do vínculo. Usar consentimento APENAS pra tratamentos genuinamente facultativos: newsletter institucional voluntária, autorização pra uso de imagem em material promocional, programa opcional de benefícios.

- **6. Quando preciso elaborar RIPD?**

Quando o tratamento pode gerar riscos às liberdades civis e direitos fundamentais (Art. 38 LGPD). Critérios práticos: (a) trata dados pessoais SENSÍVEIS — saúde, opinião política, etnia, biometria; (b) trata dados de CRIANÇAS/ADOLESCENTES sistematicamente; (c) LARGA ESCALA — milhares ou milhões de titulares; (d) DECISÕES AUTOMATIZADAS com efeitos jurídicos; (e) MONITORAMENTO SISTEMÁTICO — CFTV, geolocalização contínua; (f) TECNOLOGIAS INOVADORAS — IA, biometria. Se 1 ou mais critérios → RIPD recomendado.

- **7. O que fazer se ocorrer um incidente (vazamento)?**

Fluxo em 7 passos: (1) DETECTAR e isolar o sistema/processo afetado; (2) ACIONAR o PRI — equipe ETIR, DPO, TI, Jurídico, Alta Gestão; (3) CLASSIFICAR a severidade — fatores objetivos (acesso, sensíveis, vulneráveis, volume, exposição); (4) COMUNICAR à ANPD em até 3 dias úteis se severidade ALTA/CRÍTICA (Art. 48 + Res. 15/2024); (5) COMUNICAR aos titulares afetados em até 7 dias úteis se ALTA/CRÍTICA; (6) MITIGAR — medidas técnicas (revogar acesso, alterar senhas, restaurar backup) + administrativas (apuração, treinamento); (7) DOCUMENTAR tudo em registro interno — vira insumo da revisão anual do PGP.

- **8. Preciso publicar Aviso de Privacidade mesmo sendo órgão público?**

SIM. A obrigação de informação ao titular (Art. 9º LGPD) aplica-se a TODOS os controladores, incluindo órgãos públicos. O Aviso de Privacidade é a forma operacional de cumprir esse direito — texto público no portal externo informando quem trata, com que finalidade, base legal, retenção, compartilhamentos e como exercer direitos. Recomendado: 1 Aviso institucional + Avisos específicos pra serviços de maior impacto.

- **9. Carta de Serviços já não basta — por que preciso de Inventário também?**

Carta de Serviços (Lei nº 13.460/2017) descreve o que o órgão OFERECE ao cidadão. Inventário (Art. 37 LGPD) descreve COMO o órgão TRATA dados pessoais por trás de cada serviço. Cumprem funções diferentes: Carta = transparência sobre serviços; Inventário = conformidade no tratamento de dados. A Carta é fonte EXCELENTE pra construir o Inventário (cada serviço = potencialmente 1 processo), mas não substitui.

- **10. Posso compartilhar dados de cidadãos com outros órgãos públicos?**

PODE, com regras. Art. 26 LGPD permite uso compartilhado de dados entre órgãos públicos quando: (a) há finalidade específica de execução de políticas públicas e atribuição legal; (b) o tratamento posterior é compatível com a finalidade original (não pode ser uso secundário estranho); (c) o titular é informado (no Aviso de Privacidade). Compartilhamento com ente privado: Art. 26 §1º exige autorização específica em lei (ex: cessão de dados pra empresa contratada — só com cláusulas LGPD no contrato).

- **11. O que faço com os contratos antigos sem cláusulas LGPD?**

ADITAMENTO. Promover aditivo contratual incluindo as cláusulas mínimas do Art. 39 LGPD (segurança, comunicação de incidentes, subcontratação, direitos do titular, retenção/devolução, auditoria, responsabilidade). Ver modelo de cláusulas no capítulo VII desta Cartilha. Não é necessário rescindir — basta aditar. Pra contratos com valor significativo ou tratamento de dados sensíveis, priorizar nos primeiros 90 dias do programa de adequação.

- **12. Posso enviar newsletter institucional pra quem usou os serviços do órgão?**

DEPENDENTE. Se a newsletter está dentro da finalidade original do tratamento (ex: informações sobre o serviço que ele usou), pode dentro da mesma base legal. Se é

finalidade DIFERENTE (ex: informativo cultural mensal pra quem fez uma denúncia na Ouvidoria), exige CONSENTIMENTO específico — não cabe usar legítimo interesse genérico. Caixa pré-marcada de aceite é inválida (Art. 8º). Opt-in real obrigatório.

- **13. Sou Câmara/Tribunal — a LGPD aplica-se a sessões públicas e transmissões?**

Aplica-se com particularidades. Sessões públicas e seus registros têm base no princípio da publicidade do Art. 37 da Constituição — finalidade pública legítima. PORÉM: (a) participantes (não autoridades) precisam ser INFORMADOS no formulário de inscrição que haverá transmissão e qual o alcance; (b) uso secundário (ex: reels editados pra Instagram) exige base própria — não cabe na finalidade da transmissão original; (c) dados sensíveis eventualmente mencionados em sessão merecem cuidado redacional na divulgação.

- **14. Tenho que comunicar TODO incidente à ANPD, mesmo os pequenos?**

NÃO. Art. 48 LGPD e Res. CD/ANPD nº 15/2024 exigem comunicação quando o incidente PODE ACARRETAR RISCO OU DANO RELEVANTE aos titulares. Incidentes de severidade BAIXA (afetam poucos titulares com dados não-sensíveis e medidas de mitigação rápidas) podem ficar só no registro interno. Severidade MÉDIA/ALTA/CRÍTICA: comunicar ANPD (e aos titulares se ALTA/CRÍTICA). Usar fatores objetivos pra classificar (acesso confirmado, sensíveis, vulneráveis, volume, exposição).

- **15. Quanto custa implementar a LGPD?**

Depende fortemente do porte. Pequeno (~30 servidores): R\$ 5-15 mil/ano em treinamento e consultoria pontual. Médio (~100 servidores): R\$ 30-80 mil/ano com treinamento estruturado e eventual ferramenta. Grande (200+): R\$ 150 mil+/ano com plataforma SaaS, consultoria especializada, infraestrutura. CUSTO ZERO é miragem — mas custo BAIXO é viável em órgão pequeno com servidor capacitado.

- **16. Como diferenciar Inventário, RIPD, GAP e Plano de Ação?**

São instrumentos distintos e complementares: ****Inventário**** descreve TUDO que é tratado (quais dados, quais processos, qual base legal); ****GAP**** avalia O QUE FALTA (quais controles obrigatórios não cumprimos ainda); ****RIPD**** avalia o RISCO RESIDUAL nos processos de alto impacto (o que pode dar errado e como

mitigar); ****Plano de Ação**** organiza COMO CORRIGIR as lacunas do GAP + os riscos altos identificados. Inventário e GAP são panoramas; RIPD é zoom no crítico; Plano é execução.

- **17. A LGPD pode multar órgão público?**

Sim, mas as sanções são adaptadas ao setor público. A ANPD pode aplicar: advertência, publicização da infração, bloqueio/eliminação dos dados, suspensão parcial/total das atividades de tratamento. MULTAS PECUNIÁRIAS (Art. 52 §1º) aplicam-se a entes privados — pra entes públicos, a sanção financeira tem efeito orçamentário-disciplinar (responsabilização do gestor). Em sede de Justiça, indenizações civis (Art. 42) por dano coletivo/individual são aplicáveis a órgãos públicos.

- **18. Como capacitar a equipe sem orçamento dedicado?**

5 caminhos com custo zero ou muito baixo: (1) Materiais GRATUITOS da ANPD (Guias Orientativos no portal); (2) ENAP — cursos online gratuitos de LGPD pra servidores públicos; (3) Trilha LGPD Descomplicada — e-books gratuitos na biblioteca pública; (4) Capacitação INTERNA — DPO capacita Comitê, Comitê capacita áreas (cascata); (5) Pílulas semanais por e-mail — 1 pergunta por semana sobre situações reais. Trilha vem antes do orçamento, não depois.

- **19. Quando devo revisar o PGP?**

Ciclo recomendado: revisão ANUAL completa (todos os instrumentos) + atualização CONTÍNUA conforme eventos disparadores: (a) novo sistema ou processo; (b) alteração legislativa; (c) decisão ANPD com efeito sobre o programa; (d) incidente de severidade ALTA/CRÍTICA; (e) reorganização institucional relevante. Revisão sem atualização contínua envelhece rápido — o programa precisa respirar com a Instituição.



CAPÍTULOS DE CONSULTA • REFERÊNCIAS

Referências externas curadas

Lista mínima e curada. Não busca exaustividade — busca ENTREGAR aquilo que efetivamente é usado no dia-a-dia da implementação. A ANPD publica regularmente novos materiais; consultar o portal `gov.br/anpd` periodicamente.



Legislação fundamental

Lei nº 13.709/2018 — LGPD (texto integral)

Texto consolidado no Planalto. Leitura obrigatória pra Encarregado e Comitê.

https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm

Lei nº 12.527/2011 — LAI

Lei de Acesso à Informação. Convive com a LGPD no setor público — transparência ativa não dispensa proteção de dados pessoais.

https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2011/lei/l12527.htm

Lei nº 13.460/2017 — Defesa do Usuário

Código de Defesa do Usuário do Serviço Público. Define direito à Carta de Serviços.

https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2017/lei/l13460.htm

Marco Civil da Internet (Lei nº 12.965/2014)

Convive com a LGPD nas atividades de tratamento via Internet.

https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l12965.htm



Resoluções da ANPD

Resolução CD/ANPD nº 2/2022

Agentes de pequeno porte (microempresa, EPP, startups, pessoas físicas). Critérios de alto risco. Aplicável ao setor público?

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/legislacao/resolucoes>

Resolução CD/ANPD nº 4/2023

Regulamento de dosimetria e aplicação de sanções administrativas.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/legislacao/resolucoes>

Resolução CD/ANPD nº 15/2024

Comunicação de incidente de segurança com dados pessoais.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/legislacao/resolucoes>

Resolução CD/ANPD nº 18/2024

Atuação do Encarregado pelo Tratamento de Dados Pessoais.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/legislacao/resolucoes>

Resolução CD/ANPD nº 20/2024

Transferência internacional de dados pessoais.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/legislacao/resolucoes>



Guias e materiais didáticos da ANPD

Guia Orientativo — Atuação do Encarregado

Detalhamento prático das atribuições do DPO, perfil recomendado, conflito de interesse.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guias-orientativos>

Guia Orientativo — Tratamento por órgãos públicos

Capítulo IV da LGPD aplicado às especificidades do setor público.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guias-orientativos>

Guia Orientativo — Segurança da Informação

Medidas técnicas e administrativas mínimas pra proteção de dados pessoais.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guias-orientativos>

Guia Orientativo — Cookies e Proteção de Dados

Aplicação da LGPD a tecnologias de rastreamento em sites eletrônicos.

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guias-orientativos>



Materiais didáticos complementares

Trilha LGPD Descomplicada — Clube do Servidor

Biblioteca de e-books interativos para as 7 Fases do PGP. Recomendado para capacitação contínua da equipe.

https://heyzine.com/shelf/trilha_lgpd_descomplicada.html

Cartilha LGPD para agentes públicos (CGU)

Material da Controladoria-Geral da União com foco em servidores públicos.

<https://www.gov.br/cgu/pt-br>

ABNT NBR ISO/IEC 27701:2019

Sistema de Gestão de Privacidade da Informação. Padrão internacional referenciado em diversos guias ANPD.

<https://www.abntcatalogo.com.br>



Roteiros de implementação por prazo

A escolha do prazo de implementação depende do contexto: pressão externa (auditoria, fiscalização, incidente recente) acelera; orçamento e cultura institucional condicionam. Aqui 3 roteiros típicos — escolher o mais realista pra sua Instituição.



30 dias — EMERGENCIAL

Pressão externa imediata: notificação ANPD, fiscalização TCE/CGU, incidente público, mudança de gestão exigindo demonstração rápida. Foco em ENTREGAS MÍNIMAS DEFENSÁVEIS — não programa maduro.

- **Marcos**

- ▶ Semana 1 — Designar Encarregado por ato formal + publicar contatos no portal + iniciar Inventário (5 processos mais críticos)
- ▶ Semana 2 — Concluir 5 processos no Inventário + identificar 3 riscos altos + Plano de Ação inicial
- ▶ Semana 3 — Publicar Aviso de Privacidade básico (institucional) + estabelecer canal DSR (e-mail funcional) + comunicar incidentes anteriores se aplicável
- ▶ Semana 4 — Sessão da Alta Gestão aprovando Política do PGP (versão inicial) + cronograma dos próximos 90 dias

Entregáveis:

Ato de Designação publicado · Inventário de 5 processos · Aviso de Privacidade público · Canal DSR funcional · Política do PGP versão inicial assinada.



90 dias — ESTRUTURADO

Sem pressão externa imediata, mas com determinação institucional de implementar bem. É o prazo MAIS RECOMENDADO pra a maioria das Instituições — equilibra qualidade e velocidade.

- **Marcos**

- ▶ Semanas 1-2 — Termômetro Institucional + Carta pra Alta Gestão + designar Encarregado e Comitê
- ▶ Semanas 3-4 — Levantamento de setores + Matriz de Priorização (Res. ANPD nº 2/2022) + selecionar processos prioritários
- ▶ Semanas 5-7 — Inventário detalhado dos 10-15 processos prioritários (base legal, tipos de dados, retenção, compartilhamentos, medidas)
- ▶ Semanas 8-9 — Análise de Riscos + GAP Analysis (pacote 30 controles)
- ▶ Semanas 10-11 — Plano de Ação consolidado + iniciar RIPDs dos processos de alto risco
- ▶ Semana 12 — Publicar Aviso de Privacidade · estruturar canal DSR · cadastrar Operadores com cláusulas LGPD · esboçar PRI
- ▶ Semana 13 — Sessão da Alta Gestão: aprovação formal do PGP completo + apresentação dos próximos 90 dias de execução

Entregáveis:

PGP completo aprovado · Inventário com 10-15 processos · RIPDs dos críticos · Aviso · DSR · Operadores com cláusulas · PRI inicial.



12 meses — CONSOLIDAÇÃO

Pra órgãos que já têm PGP inicial implementado (típico dos 90 dias) e querem AMADURECER. Foco em cobertura ampliada, capacitação contínua e ciclo de melhoria.

- **Marcos**

- ▶ Trimestre 1 — Estender Inventário pra todos os setores (meta: 50%+ dos processos institucionais cobertos)
- ▶ Trimestre 2 — RIPDs pra todos os processos de alto risco · GAP completo (119 controles) · adequação dos contratos antigos com operadores
- ▶ Trimestre 3 — Programa permanente de capacitação · simulado anual de incidente (tabletop) · revisão semestral do PGP

- ▶ Trimestre 4 — Cobertura total do Inventário · indicadores institucionais (% DSR no prazo, % contratos com cláusulas, % servidores capacitados) · auditoria anual interna · relatório executivo à Alta Gestão

Entregáveis:

PGP maduro com indicadores · Inventário com 80-100% de cobertura · Programa de capacitação contínuo · Auditoria interna anual · Política revisada.

Recomendação

Priorizar o ****roteiro de 90 dias**** como padrão. Emergencial só em pressão real (não é regra). Doze meses é continuidade, não início — começar SEMPRE com algum entregável visível em 30-90 dias pra criar tração institucional.



CAPÍTULOS DE CONSULTA • ENCERRAMENTO

Encerramento

Esta Cartilha condensa, em formato pragmático, a experiência prática de implementação da LGPD em órgãos públicos brasileiros. Não é o ponto final — é ponto de partida estruturado pra que cada Instituição construa o seu próprio Programa de Governança em Privacidade.

Três princípios institucionais valem destacar no fechamento:

- ▶ ****Patrocínio da Alta Gestão**** é condição prévia. Sem decisão estratégica explícita do dirigente máximo, qualquer esforço técnico vira papel.
- ▶ ****O programa respira com a Instituição.**** Inventário, GAP, Plano e PRI são instrumentos vivos — exigem manutenção. Programa congelado envelhece em meses.
- ▶ ****Cultura supera procedimento.**** Documentos bem feitos sem cultura institucional são apenas papel. A capacitação contínua e o exemplo das chefias importam mais que qualquer checklist.



Onde buscar ajuda

- ▶ ****ANPD**** — Autoridade Nacional, primeira fonte oficial. Portal `gov.br/anpd` reúne Resoluções, Guias e canal de comunicações.
- ▶ ****ENAP**** — Escola Nacional de Administração Pública, cursos gratuitos pra servidores sobre LGPD.
- ▶ ****Comunidade técnica**** — grupos de DPOs do setor público trocam experiências em listas e fóruns. Privacy by Design não é solitário.

Boa jornada na implementação do PGP da sua Instituição.

PGP Treinamento • Cartilha institucional